Designing a Corporate IT Security Governance Framework for a Mid-sized Organisation

Case organisation: Cortexa AI

Information Security (ISC 402) Advanced Diploma, Semester 2, 2026 School of Information Technology

Group members:

- Amity Brown (s227649087)
- Rohit Aroonslam (s227876075)
- Marcellos von Buchenroder (s228139759)
- Jodi Cunningham (s224113283)
- Bantu-Bethu Beya (s227313682)
- Cameron Rademakers (s227328582)

Table of Contents

1. Executive Summary
2. Topic 1: Corporate Governance - Governance Failure Case Study
3. Topic 2: IT Governance Structure (COBIT)
4. Topic 3: InfoSec & InfoSec Governance - Roles Assessment
5. Topic 4: The InfoSec Governance Model - Direct-Execute-Control Cycle
6. Topic 5: Best Practice Standards & Guidelines
7. Topic 6: Direct Part of the InfoSec Model - Board Structure & Policy Architecture
8. Topic 7: Control Part of the InfoSec Model - Operational Policies & Compliance
9. Topic 8: IT Risk Management - Assessment & Mitigation
10. Topic 9: InfoSec Education, Training & Awareness (SETA)
11. Conclusion
12. References

Corporate IT Security Governance Framework - Cortexa AI

Executive Summary

Cortexa AI is a mid-sized machine-learning and AI solutions company (~350 employees) that builds predictive-analytics products for finance and retail clients. Like many South African organisations, it faces inadequate security funding, a shortage of skilled InfoSec professionals, ageing controls around its rapidly-scaling ML infrastructure, and low staff awareness of information security risk - while simultaneously carrying AI-specific exposure that most governance frameworks were never designed for: proprietary model theft, poisoned or biased training data, and dependence on third-party AI vendors.

This document designs a Corporate Information Security Governance Framework for Cortexa AI, built up across nine areas: lessons from historical governance failure, IT governance structure, InfoSec roles and responsibilities, a governance model, a standards comparison and recommendation, executive/board oversight, operational policies and controls, risk assessment and mitigation, and a security awareness programme. Together these give Cortexa AI's leadership a practical, evidence-based structure for managing information security as a governed, board-visible function rather than an ad hoc IT concern.

Topic 1: Corporate Governance - Governance Failure Case Study

King IV definition (South Africa's governance benchmark): Corporate Governance is the exercise of ethical and effective leadership by the governing body towards four outcomes - Ethical culture, Good performance, Effective control, and Legitimacy (IoDSA, 2016). King IV Principle 11 requires the governing body to: assume responsibility for risk governance, treat risk as integral to decision-making, set risk policy, delegate risk management to management, exercise ongoing oversight, seek independent assurance on risk-management effectiveness, and disclose risk without exposing sensitive detail.

The Direct-Execute-Control cycle (Von Solms and Von Solms, 2006): Corporate governance operates as a loop across three management levels - the Board/Executive Management **directs** by issuing Directives; Senior/Middle Management translates these into Policies, Company Standards, and Procedures; Lower Management/Administration **executes** them. Results flow back up through **control**: measurement, monitoring, and reporting at each level. A governance failure is, structurally, a break somewhere in this Direct-Execute-Control loop.

Governance as direction and control: across the many competing definitions of corporate governance, a single theme recurs: governance consists of directing (planning and assigning responsibility) and controlling (verifying implementation and enforcing compliance) (Nelson Mandela University, 2026a). In South Africa the benchmark is the voluntary King IV code, first initiated by the King Committee in 1994 (IoDSA, 2016); internationally, the G20/OECD Principles of Corporate Governance play a comparable role (OECD, 2023). King IV treats risk (the likelihood of an uncertain event multiplied by its effect) as integral to governance, which is why Principle 11 above provides the evaluative lens for the case that follows.

Case study - Enron (2001): Enron's collapse shows the loop breaking at both ends. At the Direct end, the Board's audit committee lacked the independence and expertise to issue meaningful risk directives on off-balance-sheet entities (violating King IV's "assume responsibility for risk governance"). At the Control end, external auditors (Arthur Andersen) held conflicting commercial incentives, so no independent assurance reached the board (violating King IV's "seek independent assurance") - risk was never disclosed, let alone controlled.

At the time of its bankruptcy filing on 2 December 2001, Enron was the seventh largest public company in the United States, and an estimated $27 billion of assets, nearly half its reported total, had been kept off its balance sheet through special purpose entities (Healy and Palepu, 2003; US Senate PSI, 2002).

Before its collapse Enron reported gross revenues that had risen from US$40 billion in 1999 to US$100 billion in 2000 and employed more than 20,000 people worldwide (US Senate PSI, 2002). The case is instructive precisely because the company possessed the outward apparatus of good governance: a code of conduct, a board with an audit and compliance committee operating under a formal charter, and one of the world's largest audit firms. Its failure therefore cannot be attributed to an absence of governance structures; it was a failure of governance substance.

Governance Failures Identified

Six distinct failure points can be identified in the Senate's findings and the academic literature. Each is examined below and then summarised against King IV and the Direct-Execute-Control cycle in the table that follows.

Compromised ethical leadership and conflicts of interest. Enron's code of conduct expressly prohibited employees from profiting personally from entities that transacted with the company. The Board nonetheless approved waivers in 1999 permitting the Chief Financial Officer, Andrew Fastow, to establish and manage the LJM private equity partnerships, which then transacted with Enron and "realized hundreds of millions of dollars in profits at Enron's expense" (US Senate PSI, 2002). By suspending its own ethical safeguards, the governing body corrupted the Direct function at its source, violating King IV Principles 1 and 2 on ethical and effective leadership and an ethical organisational culture (IoDSA, 2016).

Failure of risk governance. The Senate Permanent Subcommittee on Investigations found that the Board "knowingly allowed Enron to engage in high-risk accounting practices" (US Senate PSI, 2002). Rather than setting a prudent risk appetite, the Board tolerated structures designed to make the company's financial condition "appear better than it was". This contravenes King IV Principle 11: the governing body neither treated risk as integral to its decisions nor ensured that the nature and extent of that risk were disclosed.

Ineffective audit committee oversight. The Audit and Compliance Committee was chartered to assess internal controls, review the financial statements and ensure the independence of the auditor. In February 1999 Andersen briefed the Committee that Enron's accounting practices "push limits" and were "at the edge" of acceptable practice, and similar briefings followed once or twice annually until 2001; Andersen's own internal client-risk assessments placed Enron in the "maximum" risk category (US Senate PSI, 2002). The information required for control therefore reached the top of the organisation, but the Committee did not act on it: the Control leg of the cycle functioned mechanically yet failed substantively, contrary to King IV Principles 8 and 15 on the effective use of committees and on assurance (IoDSA, 2016).

Absence of independence. The Board's independence was compromised by financial ties between the company and certain directors, and the Board failed to safeguard the independence of its external auditor (US Senate PSI, 2002). Andersen provided substantial consulting services to Enron alongside the statutory audit, creating an incentive to preserve a lucrative client relationship rather than to challenge it (Healy and Palepu, 2003). King IV Principle 7 calls for an appropriate balance of knowledge, skills, experience, diversity and independence on the governing body; its absence meant that no party with both the authority and the detachment to object was positioned to do so.

Misaligned remuneration. The Board approved excessive executive compensation and failed to monitor the cumulative cash drain of Enron's 2000 bonus and performance unit plans (US Senate PSI, 2002). Incentives linked to reported earnings and share price rewarded the appearance of performance rather than its substance (Healy and Palepu, 2003), contrary to King IV Principle 14, which requires remuneration that is fair, responsible and transparent and that promotes the achievement of strategic objectives in the short, medium and long term.

Deficient disclosure and transparency. Billions of dollars of off-the-books activity were conducted without adequate disclosure to shareholders, lenders or employees (US Senate PSI, 2002). The organisation's legitimacy, which King IV identifies as a core governance outcome, cannot survive the discovery that stakeholders were denied a truthful account of the risks to which their capital and livelihoods were exposed.

The table below summarises each failure point, the King IV principle it violated and the break in the Direct-Execute-Control cycle that it represents.

Failure point	Evidence	King IV principle violated	Break in the cycle
Ethical leadership	Code of conduct waived to let the CFO run conflicted partnerships that transacted with Enron	Principle 1 (Leadership); Principle 2 (Ethical culture)	Direct: the directive itself was corrupted at the source
Risk governance	Board knowingly permitted high risk accounting and off balance sheet structures	Principle 11 (Risk governance)	Direct: no prudent risk appetite was set
Audit committee oversight	Repeated warnings that practices "pushed limits" were received but never acted on	Principle 8 (Committees); Principle 15 (Assurance)	Control: reports reached the top but were ignored
Independence	Directors held financial ties to the company; the external auditor was also a major consulting client	Principle 7 (Composition); Principle 15 (Assurance)	Control: assurance was not independent
Remuneration	Bonus and performance unit plans rewarded reported earnings rather than real performance	Principle 14 (Remuneration)	Execute: behaviour was steered by the wrong incentives
Disclosure	Approximately $27 billion held off balance sheet without adequate disclosure to stakeholders	Principle 5 (Reporting); Principle 11 (Disclosure)	Control: risk was never reported to stakeholders

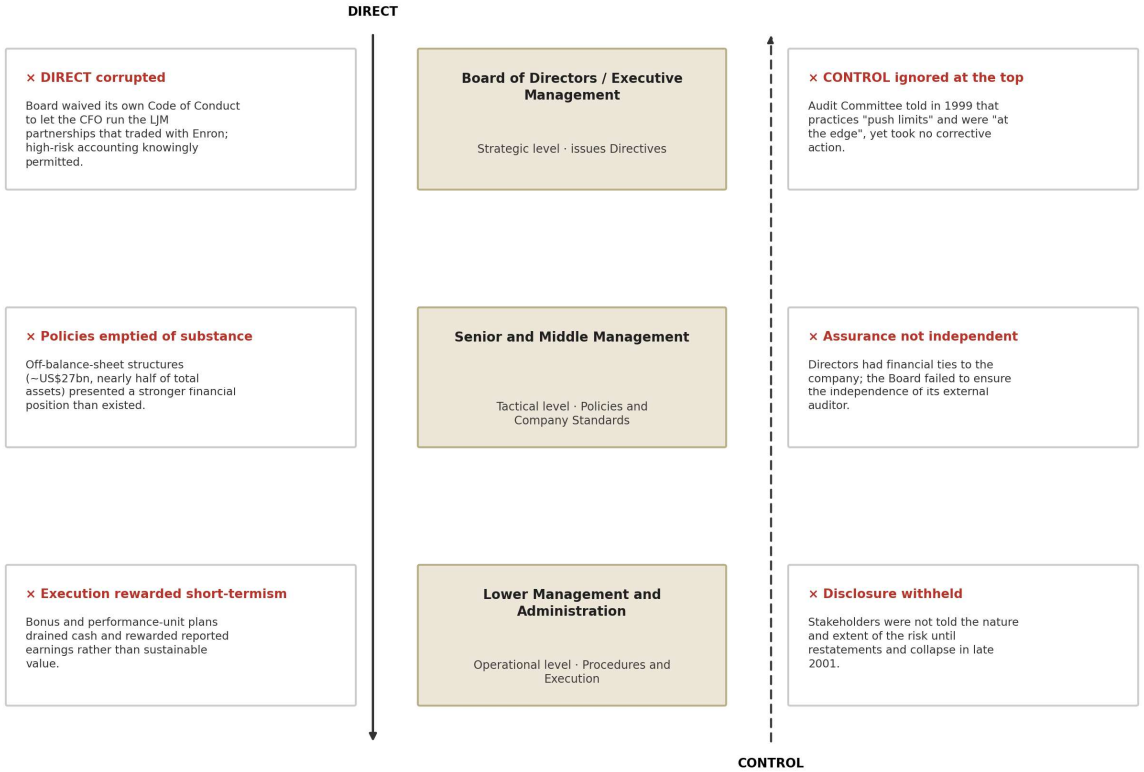


Figure 1: The Enron failures positioned on the Direct-Control cycle (adapted from Von Solms and Von Solms, 2006; US Senate PSI, 2002)

Applying this to Cortexa AI: the same break can occur if a predictive-analytics model ships to production without a Board-level directive on acceptable AI risk, and without a control mechanism (monitoring, reporting) that surfaces model risk back up to the board. Cortexa AI's governance failure risk is therefore the same structural gap as Enron's - not a one-off technical mistake, but a break in the Direct-Execute-Control loop.

This Enron analysis is used as a structural analogy: it draws only on widely documented governance failures (board and audit committee independence gaps, conflicted external auditors) and does not assert any further technical or accounting detail beyond what is publicly reported.

Direct-Execute-Control stage	Enron failure	Cortexa AI risk analogue
Direct (strategic)	Audit committee issued no real risk directive on off-balance-sheet vehicles	No board directive exists on acceptable AI/model risk before release
Execute (tactical/operational)	Management structured deals to obscure risk from directives that did exist	Engineering ships models without translating any directive into a policy/procedure
Control (all levels)	Conflicted auditors provided no independent assurance; risk undisclosed	No monitoring/reporting loop surfaces model risk (bias, security, drift) back to the board

Critical analysis: three observations emerge from a critical reading of the case.

First, the failures were systemic rather than isolated. Each breakdown enabled the next: the ethics waiver created the conflicted entities; the high-risk accounting concealed their effect; the lack of independence prevented anyone from challenging the concealment; and the incentive structure rewarded all of it. An analysis that attributes the collapse to a handful of dishonest executives underestimates the extent to which the governing body itself sanctioned the conditions for fraud.

Second, the case exposes the limits of compliance-oriented, "tick-box" governance. Enron possessed every structure that a checklist would demand. What it lacked was the ethical will and the independent judgement to make those structures operate as intended. This is the principal rationale for King IV's outcomes-based "apply and explain" approach, which asks organisations to demonstrate that principles are producing the intended outcomes rather than merely asserting that mechanisms exist (IoDSA, 2016). A reasonable counter-argument is that voluntary codes lack enforceability; the United States responded to Enron with binding legislation in the form of the Sarbanes-Oxley Act of 2002. The more defensible position is that law and principle are complementary: legislation sets the floor, whereas governance culture determines whether an organisation merely clears it.

Third, the lesson extends beyond financial reporting to technology risk. The course reasons syllogistically: accountability for corporate governance rests with the Board; King IV makes risk governance an essential practice of corporate governance; IT-related risks are among the most significant risks an organisation faces; therefore the Board is accountable for understanding and governing IT-related risk (Nelson Mandela University, 2026a). The July 2024 CrowdStrike incident, in which a faulty security-software update disrupted an estimated 8.5 million Windows devices worldwide (Weston, 2024), illustrates that a single technology dependency can now produce enterprise-wide operational failure with the same speed and severity as a financial scandal.

Translating Enron's failure points into safeguards for Cortexa AI: because Cortexa AI's most valuable assets (proprietary models, training data and client data) are intangible, fast-changing and poorly understood by non-specialist directors, its board faces exactly the condition in which deferring uncritically to management is most tempting. The table below translates each Enron failure point into a Cortexa-specific risk and the safeguard adopted in this framework. The analogues are illustrative and do not assert any misconduct by Cortexa AI.

Enron failure	Cortexa AI analogue (risk)	Governance safeguard adopted
Conflict of interest	The CTO who is rewarded for shipping models quickly also approves security exceptions for those models	CISO reports to the CEO, not the CTO; security exceptions require CISO sign-off (Topics 3 and 6)
High-risk accounting	Overstating model accuracy or understating limitations to win finance and retail contracts	Model risk and performance claims reviewed by the Risk, Audit & Technology Committee against a Board-approved AI risk appetite
Ineffective oversight	Model drift, bias or security alerts logged by engineers but never escalated	Defined reporting line from the MEA domain to the Committee each quarter (Topic 2)
Lack of independence	Security assurance performed only by the teams that built the systems	Internal Audit reports functionally to the Committee; periodic external assurance on ISG
Misaligned remuneration	Engineering bonuses tied solely to deployment velocity	Balanced scorecards that include security and compliance metrics
Deficient disclosure	Security compromises affecting client personal information not disclosed	POPIA section 22 notification procedure owned by the Information Officer (Topic 3)

Conclusion: governance exists to keep the Direct-Execute-Control loop unbroken - King IV's outcomes (ethical culture, effective control, legitimacy) (IoDSA, 2016) are what result when it holds; Enron and any future Cortexa AI failure are what result when it doesn't. The rest of this framework (Topics 2-9) is built to keep that loop intact for Cortexa AI specifically.

Topic 2: IT Governance Structure (COBIT)

Definition (course): IT Governance (ITG) is the responsibility of the Board of Directors and Executive Management. It is an integral part of Corporate Governance, consisting of the leadership, organisational structures, and processes that ensure the organisation's IT sustains and extends its strategies and objectives.

Two features of this definition deserve emphasis. First, accountability rests at the top of the organisation rather than with the IT department. Second, ITG is a component of corporate governance, standing alongside financial and human-resources governance, so that the IT function operates a sub-governance of its own over the IT environment and its associated risks (Von Solms and Von Solms, 2006). King IV gives this position formal expression in Principle 12, which requires the governing body to govern technology and information in a way that supports the organisation in setting and achieving its strategic objectives (IoDSA, 2016). For Cortexa AI the argument is especially strong: the company's products are its information technology. Its trained models, data pipelines and cloud platforms constitute both its operating infrastructure and its principal source of competitive advantage, so a failure of IT governance is indistinguishable from a failure of corporate strategy.

The five ITG objectives, applied to Cortexa AI:

ITG Objective	What it requires	Cortexa AI application
Strategic Alignment	Business and IT plans linked; regular stakeholder communication	AI product roadmap reviewed jointly by CTO and business leadership, not engineering alone
Value Delivery	IT delivers promised benefits against strategy; ROI maximised	Model deployments tracked against business KPIs, not just technical accuracy
Risk Management	IT risks (breaches, data loss, downtime) continuously identified and addressed	Model/data risks folded into enterprise risk register (see Topic 8)
Resource Management	IT resources used effectively/efficiently	Cloud GPU spend and data-labelling contracts reviewed for efficiency and risk together
Performance Management	IT initiatives' success measured and monitored	Model performance AND security/compliance metrics reviewed together, not separately

COBIT 2019 (ISACA, 2018b): a best-practice framework for IT management and governance, built around five governance/management domains - Evaluate, Direct, Monitor (EDM, board-level) plus four management domains: Align/Plan/Organise (APO), Build/Acquire/Implement (BAI), Deliver/Service/Support (DSS), and Monitor/Evaluate/Assess (MEA). COBIT can be used for IT auditing, as a broad ITG completeness check, or to assess maturity.

COBIT's most important conceptual contribution is the principle that *governance is distinct from management*: governance evaluates stakeholder needs, sets direction and monitors performance, whereas management plans, builds, runs and monitors activities within the direction that governance has set. COBIT 2019 organises forty governance and management objectives across its five domains, and the single governance domain, EDM, belongs to the Board (ISACA, 2018b). It is deliberately flexible and adaptable to different industries and organisational sizes, which makes it appropriate for a mid-sized enterprise such as Cortexa AI.

COBIT's EDM domain maps directly onto the Board's role in the Direct-Execute-Control model: EDM is where the Board directs strategy and risk appetite and later exercises control by evaluating and monitoring outcomes, before the four management domains (APO, BAI, DSS, MEA) carry out the execute step.

Selected COBIT 2019 objectives mapped to Cortexa AI owners: COBIT separates governance (EDM, owned by the Board) from management (APO, BAI, DSS and MEA, owned by executive and line management) (ISACA, 2018a). The table below selects the objectives most material to an AI company and assigns each to an accountable owner, so that no objective is left without someone answerable for it.

Domain	Objective	Cortexa AI owner	Application at Cortexa AI
EDM	EDM01 Ensured governance framework setting and maintenance	Board	Adopts this framework; defines decision rights for AI and data
EDM	EDM03 Ensured risk optimisation	Risk, Audit & Technology Committee	Sets appetite for model, data and security risk; reviews the risk profile quarterly
EDM	EDM05 Ensured stakeholder engagement	Board	Transparent reporting to clients and to the Information Regulator where required
APO	APO12 Managed risk; APO13 Managed security	CISO	Maintains the risk register and the information security management system
APO	APO14 Managed data	Head of Data & ML	Data classification, lineage and quality controls for training data
BAI	BAI03 Managed solutions identification and build; BAI06 Managed IT changes	Head of ML Engineering	Secure ML development lifecycle; model registry; change approval before release
DSS	DSS04 Managed continuity; DSS05 Managed security services	Cloud & IT Operations Lead	Backups of model weights; access control; endpoint and network protection
MEA	MEA03 Managed compliance with external requirements; MEA04 Managed assurance	Internal Audit	Independent testing of POPIA and security controls; findings reported to the Committee

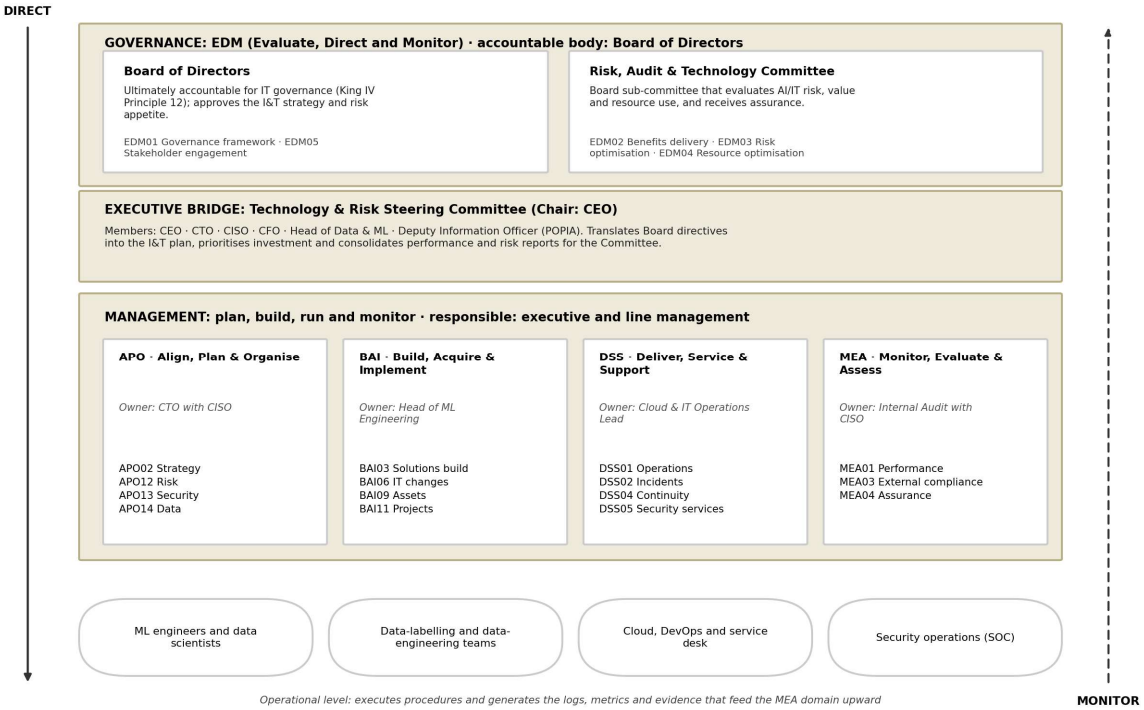


Figure 2: Cortexa AI IT governance structure mapped to COBIT 2019 (ISACA, 2018b) and ISO/IEC 38500 (ISO/IEC, 2015)

Figure 2 deliberately mirrors the Direct-Execute-Control cycle from Topic 1. The Board and its Risk, Audit & Technology Committee direct through the EDM domain; a Technology & Risk Steering Committee chaired by the CEO translates that direction into plans; the four management domains execute; and the MEA domain closes the loop by returning performance, compliance and assurance findings to the Board. An executive steering committee suits a company of Cortexa AI's size: it avoids the cost of a separate board-level technology committee while ensuring that no single technology executive controls both the delivery of AI products and the reporting of their risk.

ISO/IEC 38500 complements COBIT by giving the Board a concise set of principles for governing IT: Evaluate current and future use of IT, Direct the preparation and implementation of plans and policies, and Monitor conformance and performance, applied through six principles of Responsibility, Strategy, Acquisition, Performance, Conformance and Human Behaviour (ISO/IEC, 2015). Because its Evaluate, Direct, Monitor cycle maps directly onto COBIT's EDM domain, Cortexa AI can use the two frameworks together without duplication, and the same six principles reappear in Topic 3 as the principles of information security governance.

How Cortexa AI should use COBIT: COBIT can be introduced from three viewpoints: as an IT audit reference against which processes and control objectives are examined; as a broader ITG tool for determining the completeness of an organisation's governance approach and whether it is "doing the right things"; and from a maturity perspective, to determine how far implementation has progressed (Nelson Mandela University, 2026b). Given the resource constraints typical of South African mid-sized organisations, Cortexa AI should adopt a phased sequence: first, use COBIT as a completeness check to confirm that each objective in the table above has a named owner; second, establish a baseline capability rating for each objective using COBIT 2019's capability levels (ISACA, 2018b); and third, allow Internal Audit to use the same objectives as its audit universe. This sequence yields early value without the heavy implementation burden of which COBIT is frequently accused.

CIA Triad (why IT risk matters to governance): Confidentiality (only authorised access), Integrity (only authorised changes), Availability (accessible when required) - the three properties Cortexa AI's electronic assets (training data, model weights, client API data) must maintain against threat sources (external attacks, internal misuse, human error, physical loss).

Managing IT-related risk is core to ITG because IT systems now house most, if not all, of an organisation's electronic assets: data stored in files and databases, data in transit across networks, and the software required to store, transmit and process it (Nelson Mandela University, 2026b). The table below applies this risk-threat model to Cortexa AI.

Electronic asset	Primary CIA concern	Representative threat sources	Business consequence if compromised
Client training and inference data (incl. personal information)	Confidentiality	External breach; staff pasting data into public AI tools; vendor misuse	POPIA liability; loss of finance and retail clients
Proprietary model weights and source code	Confidentiality, Integrity	Model extraction via API; insider exfiltration	Loss of intellectual property and competitive position
Training-data pipelines and labelled datasets	Integrity	Data poisoning; unauthorised or erroneous changes	Biased or inaccurate predictions delivered to clients
Model-serving APIs and cloud GPU infrastructure	Availability	Denial of service; failed updates; provider outage	Breach of client SLAs; revenue loss
Security and audit logs	Integrity, Availability	Log tampering; insufficient retention	Inability to detect, investigate or prove compliance

Where InfoSec Governance sits: the course's governance-components model places Information Security Governance (ISG) as a component of ITG, alongside Performance & Capacity Governance - but importantly, **ISG is not fully contained within ITG** (e.g. the legal/regulatory dimension of InfoSec draws on legal professionals outside the IT line function). This matters for Topic 3.

Figure 3 below illustrates the general governance components model, showing IT Governance as one of several components of Corporate Governance, and Information Security Governance positioned within IT Governance alongside Performance and Capacity Governance.

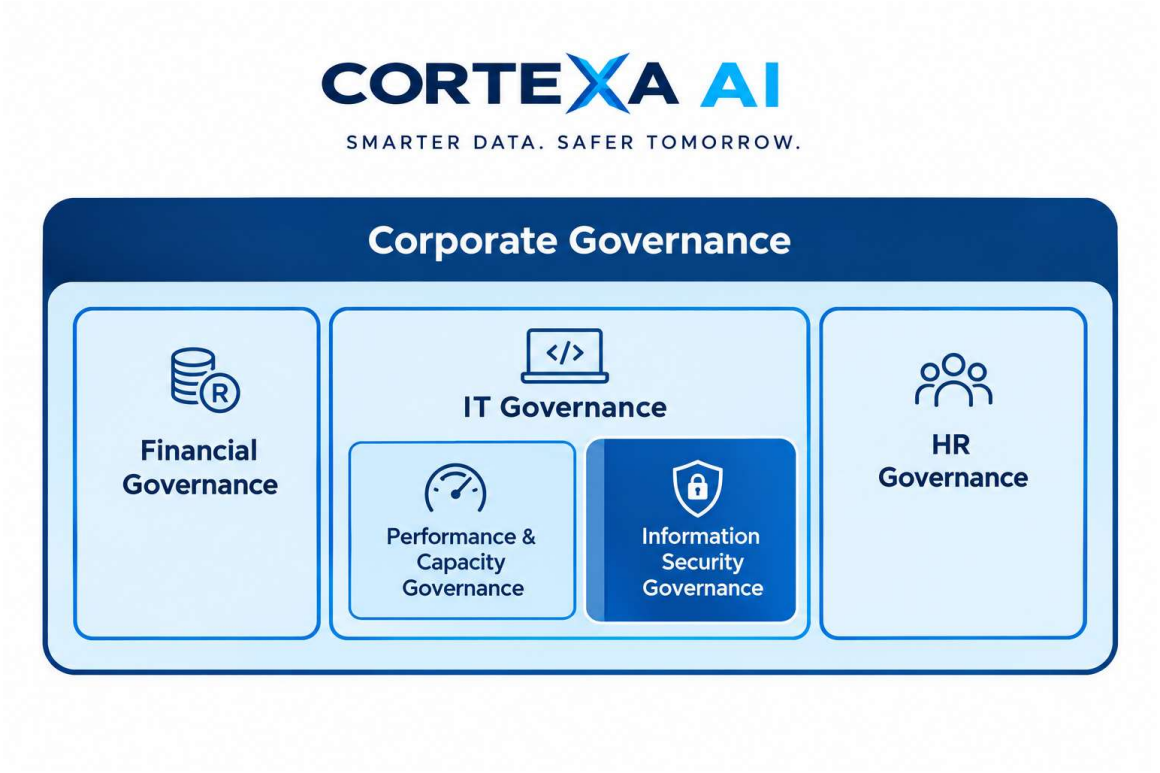


Figure 3: General governance components model

Note: for layout simplicity, this figure shows Information Security Governance nested inside IT Governance. As explained above, this is a simplification. In practice ISG is not fully contained within ITG, since ISG also has direct lines of responsibility to the Board and Executive Management that do not pass through the IT function (Von Solms and Von Solms, 2006). The figure should therefore be read as showing where ISG most closely sits in relation to ITG, not as a strict subset relationship.

Conclusion: by locating accountability with the Board, separating governance (EDM) from management (APO, BAI, DSS and MEA), assigning every material COBIT objective to a named owner and adopting ISO/IEC 38500's Evaluate-Direct-Monitor discipline, Cortexa AI converts IT governance from an engineering concern into a board-level system of direction and control. The structure also repairs, by design, each of the control weaknesses identified in the Enron case (Topic 1).

Topic 3: InfoSec & InfoSec Governance - Roles Assessment

InfoSec Governance (ISG) definition (course): the management commitment and leadership, organisational structures, user awareness, policies, procedures, technologies, and compliance-enforcement mechanisms working together to maintain the CIA of the company's electronic assets at all times. ISG is an integral part of Corporate Governance, underpinned by IT Risk Governance, with accountability resting on executive management.

Governance versus management: ISG begins at the strategic level, spans all three levels and creates the setting in which others can manage effectively; management operates at the tactical and operational levels and concerns operating decisions and the performance of functional work (Nelson Mandela University, 2026c). An organisation in which engineers diligently configure firewalls but no executive sets direction or receives reports has security management, but it does not have security governance. Effective ISG should deliver five outcomes: strategic alignment of security with business strategy; risk management that reduces potential impact on information resources to an acceptable level; resource management that aligns security budgets with enterprise requirements; value delivery that optimises security investment; and performance measurement against metrics that demonstrate whether objectives are achieved (ITGI, 2006). These outcomes deliberately mirror the ITG objectives in Topic 2, reinforcing ISG's place as a component of the wider governance system.

Information as a strategic asset: information has become a new form of currency: it informs decisions, confers competitive advantage and generates revenue, and, like any currency, it can be stolen (Nelson Mandela University, 2026c). Information security is the protection of this asset's confidentiality, integrity and availability. For Cortexa AI the proposition is literal rather than metaphorical, since the company's revenue is generated by converting client information into predictive models. The table below applies the control families recommended in the course to each element of the CIA triad.

Property	Controls recommended (course)	Cortexa AI implementation
Confidentiality	Need-to-know access; identification of sensitive data; data classification policy; staff training	Role-based access to datasets and model weights; four-tier classification (Public, Internal, Confidential, Restricted) with client personal information as Restricted
Integrity	Validation at collection and use; restricted modification rights; audit and backup processes; training	Dataset versioning and hash verification before training; signed model artefacts; change approval via the model registry
Availability	Backups; redundancy for critical systems; cloud services; disaster recovery plans; continuous monitoring	Multi-zone cloud deployment of model-serving APIs; tested restore of model weights; 24x7 monitoring against client SLAs

Information security as a multi-dimensional discipline: Von Solms (2001) argues that information security cannot be achieved through technology alone but only by implementing all of its constituent dimensions holistically, spanning strategic, tactical and operational levels and both technical and non-technical facets. There is no single, decisive solution: omitting any one dimension leaves a gap that may be exploited. Some dimensions operate top-down (governance, risk management and legal), whereas most others operate bottom-up (Nelson Mandela University, 2026c).

The table below assesses Cortexa AI against the dimensions presented in the course, using the organisational challenges identified in the problem statement (inadequate funding, a shortage of skilled professionals, ageing controls and low awareness) as the baseline.

Dimension	What the dimension requires	Cortexa AI position and gap	Primary owner
(Corporate) Governance	Board accountable for protecting information; everyone has an InfoSec responsibility	Security treated as an engineering matter; no Board directive yet	Board
Risk management	InfoSec risk forms part of enterprise risk management, not a standalone area	AI-specific risks (poisoning, model theft) absent from the risk register	CISO
Organisational	Defined roles, reporting lines and executive involvement	Roles implicit; addressed by Figure 4 and the responsibility matrix below	CEO
Management	Day-to-day tactical and operational security management	Performed ad hoc by engineers without a mandate	CISO
Policy	A Corporate Information Security Policy (CISP) before any implementation	No CISP; practices undocumented	CISO (CEO signs)
Best practice	Use of reference frameworks such as ISO/IEC 27002 and COBIT 2019	COBIT adopted (Topic 2); ISO/IEC 27002 to follow (Topic 5)	CISO
Ethical	Professional and ethical conduct of practitioners	Responsible-AI and bias concerns not yet codified	Head of Data & ML
Certification	Formal certification, e.g. ISO/IEC 27001, to build client trust	Uncertified; finance clients increasingly require it	CISO
Legal	Compliance with POPIA, ECTA and the Cybercrimes Act	Information Officer duties not formally allocated	Legal & Compliance
Insurance	Cyber-insurance, with premiums informed by security posture	Cover not yet reviewed against AI exposures	CFO
Personnel / human	Screening, onboarding and offboarding controls	Access not consistently revoked at exit	Chief People Officer
Awareness	Structured awareness programme for all users	Low awareness; unapproved use of public AI tools	CISO with HR
Technical	Controls enforcing CIA, authentication, authorisation, accountability and non-repudiation	Cloud controls exist but are inconsistently configured	Cloud & IT Operations
Measurement / monitoring	Continuous 24x7 measurement of technical and non-technical controls	Logs collected but not reviewed or reported	CISO

Dimension	What the dimension requires	Cortexa AI position and gap	Primary owner
Audit	IT governance audit of alignment, metrics and value	No internal audit coverage of IT	Internal Audit
IT forensics	Capability to investigate cyber crime and fraud	None; no evidence-handling procedure	CISO (external retainer)

The assessment reveals that Cortexa AI's weaknesses are concentrated in the top-down dimensions (governance, risk management, policy and legal). This is significant because the bottom-up dimensions depend on them: technical controls, monitoring and awareness have no mandate, no priority and no measure of success until a governance structure and a CISP define them. (Republic of South Africa, 2021)

The six Principles of Information Security Governance (used below to assign Cortexa AI's roles):

Principle	Requirement	Cortexa AI owner
Responsibility	Ownership/accountability for InfoSec; clearly defined roles	CISO (accountable, per King IV Principle 11 logic from Topic 1)
Strategy	InfoSec strategy aligned with business objectives, rooted in risk management	CISO + Board Risk oversight
Acquisition	InfoSec embedded in vendor/procurement practices	CISO + Third-party AI vendor due diligence
Performance	KPIs and monitoring of control effectiveness	CISO reporting to executive management
Conformance	Compliance with laws/regulations/standards (POPIA, Cybercrimes Act)	Information Officer (POPIA), the role held by the CEO by default under POPIA, assisted by a Deputy Information Officer (abbreviated DPO in this matrix for consistency with industry terminology)
Human Behaviour	Training, culture, human-error risk assessment	CISO + HR (feeds Topic 9's SETA programme)

Organisational structure and reporting lines: Figure 4 shows where each information security role sits and to whom it reports. Three design decisions shape it. First, the CISO reports to the CEO rather than to the CTO, with a dotted-line right of direct access to the Risk, Audit & Technology Committee, so that unfavourable security information cannot be filtered out by the executive responsible for shipping technology (the conflict of interest identified in Topic 1). Second, the CEO is the Information Officer: under POPIA the head of a private body holds this role by default and may designate Deputy Information Officers to assist (Republic of South Africa, 2013; Information Regulator, n.d.), so the Head of Legal & Compliance acts as Deputy Information Officer while statutory accountability stays with the CEO. Third, ISG extends beyond the IT line function: Legal & Compliance, People (HR) and Internal Audit carry essential security responsibilities without reporting through IT (shaded amber), which illustrates in practice that ISG is not fully contained within ITG.

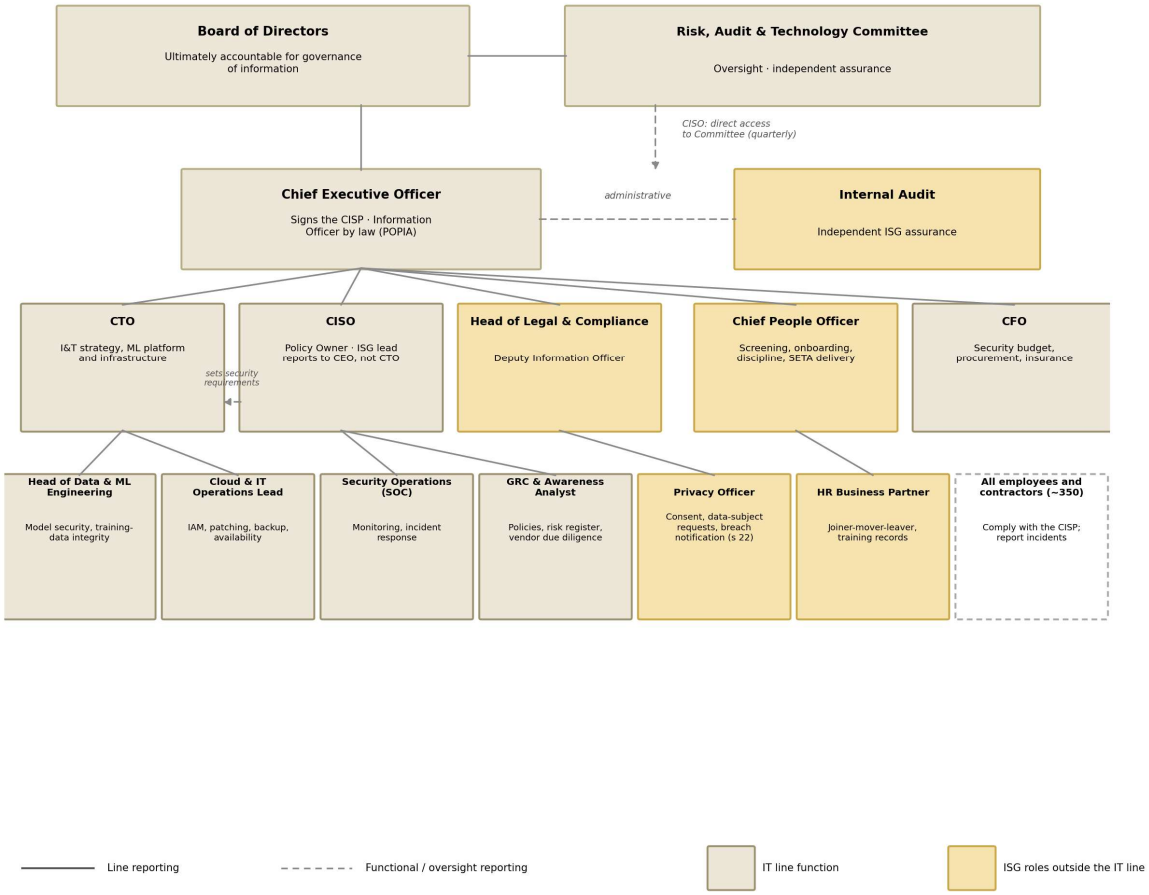


Figure 4: Proposed information security organisational structure and reporting lines for Cortexa AI

Role analysis: the table below analyses each role's governance level, its core information security responsibilities and the principle of information security governance (ISO/IEC, 2015) that it chiefly discharges.

Role	Level	Core information security responsibilities	Principle discharged
Board of Directors (via Risk, Audit & Technology Committee)	Strategic	Approves the information security strategy and risk appetite; issues the Board Directive; receives quarterly reports; obtains independent assurance	Responsibility; Strategy
Chief Executive Officer (Information Officer)	Strategic	Signs the CISP; accountable for POPIA compliance; allocates resources; chairs the Technology & Risk Steering Committee	Responsibility; Conformance
Chief Information Security Officer	Tactical	Policy Owner of the CISP; maintains the security strategy and risk register; defines security requirements for all teams; reports KPIs to the CEO and Committee	Strategy; Performance
Chief Technology Officer	Tactical	Ensures ML platforms and infrastructure are built and operated to the CISO's requirements; accountable for technical security outcomes	Acquisition; Performance
Head of Legal & Compliance (Deputy Information Officer)	Tactical	Interprets POPIA, ECTA and the Cybercrimes Act; security clauses in client and vendor contracts; manages Information Regulator engagement	Conformance
Chief Financial Officer	Tactical	Funds the security programme; ensures vendor due diligence in procurement; manages cyber-insurance	Acquisition

Role	Level	Core information security responsibilities	Principle discharged
Chief People Officer	Tactical	Pre-employment screening; joiner-mover-leaver access process; disciplinary action for policy breaches; training records	Human Behaviour
Internal Audit	Tactical (independent)	Independent assessment of ISG and control effectiveness; reports functionally to the Committee	Performance; Conformance
Head of Data & ML Engineering	Operational	Integrity of training data; secure model development; adversarial and bias testing before release	Performance; Human Behaviour
Cloud & IT Operations Lead	Operational	Identity and access management, patching, logging, backup and availability of production systems	Performance
Security Operations (in-house or managed)	Operational	Continuous monitoring, incident detection and response, evidence preservation	Performance
All employees and contractors	Operational	Comply with the CISP; complete awareness training; report incidents promptly; use only approved AI tools	Human Behaviour

(Republic of South Africa, 2021)

Cortexa AI Responsibility Matrix (R = Responsible, A = Accountable, C = Consulted, I = Informed). Each activity is aligned to one of the six ISG principles (ISO/IEC, 2015) and has exactly one Accountable party; strategic accountability rests with the Board or CEO, consistent with accountability for ISG resting on executive management, while responsibility is placed with the role that has the capability to perform the work.

Activity	ISG principle	Board	CEO	CTO	CISO	DIO	ML	Ops	HR	Audit	Staff
Approve InfoSec strategy and risk appetite	Strategy	A	R	C	C	C	I	I	I	C	I
Issue, sign and maintain the CISP and sub-policies	Responsibility	I	A	C	R	C	C	C	C	I	I
Protect personal information in training data (POPIA)	Conformance	I	A	C	C	R	R	C	I	I	I
Secure the ML model lifecycle (theft, poisoning, adversarial attack)	Performance	I	I	A	C	I	R	C	I	I	I
Operate cloud and infrastructure security controls	Performance	I	I	A	C	I	C	R	I	I	I
Due diligence and contracts for AI and cloud vendors	Acquisition	I	C	A	R	R	C	C	I	I	I
Detect, respond to and notify security compromises (POPIA s 22)	Conformance	I	I	C	A	R	C	R	I	I	R

Activity	ISG principle	Board	CEO	CTO	CISO	DIO	ML	Ops	HR	Audit	Staff
Report InfoSec KPIs and risk profile to the Board	Performance	I	A	C	R	C	I	I	I	C	I
Provide independent assurance on ISG effectiveness	Conformance	A	I	C	C	C	I	I	I	R	I
Deliver security awareness and training (SETA)	Human Behaviour		I	I	A	C	I	I	R	I	R
Screen, onboard and offboard personnel (access revocation)	Human Behaviour	I	I	C	C	I	I	R	A	I	I
Maintain continuity and recovery of model-serving systems	Performance	I	I	A	I	C	R	I	I	I	

DIO = Deputy Information Officer (Head of Legal & Compliance); ML = Head of Data & ML Engineering; Ops = Cloud & IT Operations Lead; Audit = Internal Audit; Staff = all employees and contractors.

Why this matters: ISG is *not fully contained* within ITG (Topic 2) - the Conformance principle above (POPIA compliance) sits with a Deputy Information Officer role that exists outside the IT reporting line entirely, exactly as the course model predicts. Giving every activity a single accountable (A) owner while distributing responsibility (R) to the team with the technical capability closes the "nobody owns it" gap identified in Topic 1's Direct-Execute-Control failure analysis.

The Cybercrimes Act 19 of 2020 also forms part of the legal landscape that the CISO and Information Officer must consider. The Act criminalises unlawful access to a computer system, unlawful interference with data and cyber fraud and extortion (Republic of South Africa, 2021), which are the offences Cortexa AI's systems, APIs and client data would be exposed to. Most of its offence provisions have been in force since 1 December 2021, and they apply to Cortexa AI as both a potential victim and a data custodian.

Two real cases from the course's own material illustrate this exposure concretely. In one reported Cybercrimes Act prosecution, the accused faced charges spanning unlawful access, unlawful use of software or hardware tools, interference with data, password offences, cyber fraud and attempted cyber extortion - the same offence categories Cortexa AI's API and vendor exposure would fall under in a comparable incident. Under POPIA, a South African diagnostics company was issued an administrative fine by the Information Regulator after failing to notify the Regulator and affected data subjects following a security compromise; Cortexa AI's own Information Officer led notification procedure exists specifically to avoid that outcome. (Republic of South Africa, 2021)

Critical observations:

- **Accountability is concentrated; responsibility is distributed.** The Board is accountable for only two activities, strategy and independent assurance, which is appropriate because governing bodies should direct and oversee rather than manage. The CEO holds statutory and policy accountability, and the CTO holds accountability for technical outcomes, while the CISO is responsible for designing and reporting on the control environment across all of them.

- **The CISO is Accountable for incident response, not for technology operations.** This preserves the CISO's independence: if the CISO were accountable for operating the controls that it also reports on, it would in effect be marking its own work, the same conflict that compromised Enron's auditor.
- **Conformance is shared across non-IT roles.** The Deputy Information Officer, HR and Internal Audit carry Responsible or Accountable designations for six of the twelve activities, confirming in practice that ISG is not contained within ITG.
- **Resource realism.** The skills shortage identified in the problem statement makes a large in-house security team unrealistic for a company of approximately 350 employees. The structure therefore permits Security Operations and forensic capability to be sourced from a managed provider, provided that accountability remains with named Cortexa AI executives, as the Acquisition principle requires.
- **Alignment with subsequent topics.** The CISO's role as Policy Owner anticipates the Direct part of the InfoSec model (Topic 6); the KPI reporting row provides the Control leg developed in Topics 4 and 7; and the awareness row provides the mandate for the SETA programme in Topic 9.

Conclusion: information security at Cortexa AI can succeed only if it is treated as a multi-dimensional governance discipline rather than as a technical function. The structure and responsibility matrix proposed here establish clear ownership of each dimension, place the CISO beyond the influence of the technology delivery line, recognise the statutory position of the Information Officer under POPIA and ensure that every activity has a single accountable owner. Together with the IT governance structure mapped in Topic 2, they provide the organisational foundation on which the governance model, policies, risk assessment and awareness programme in the remaining topics are built.

Topic 4: The InfoSec Governance Model - Direct-Execute-Control Cycle

Cortexa AI's InfoSec Governance Model applies the course's Direct-Execute-Control cycle (Von Solms and Von Solms, 2006) across three levels, with a defined input/output at each: (Republic of South Africa, 2021)

Level	Direct (input → output)	Control (data → report)
Strategic (Board/Exec)	Legal/regulatory factors (POPIA, Cybercrimes Act) + strategic vision → **Directives** (e.g. "protect client data and model IP at all times")	Compliance/conformance reports from tactical level → risk situation reported to Board
Tactical (CISO/DPO)	Board Directives → expanded into **policies, company standards, procedures** (Topic 6/7)	Operational measurement data aggregated → Tactical + Executive Management reports on compliance
Operational (ML Eng Lead/IT Ops)	Policies/standards → expanded into **administrative guidelines** + technical measures implemented	Data extracted from logs (firewalls, model-access logs, databases) → specialised reports

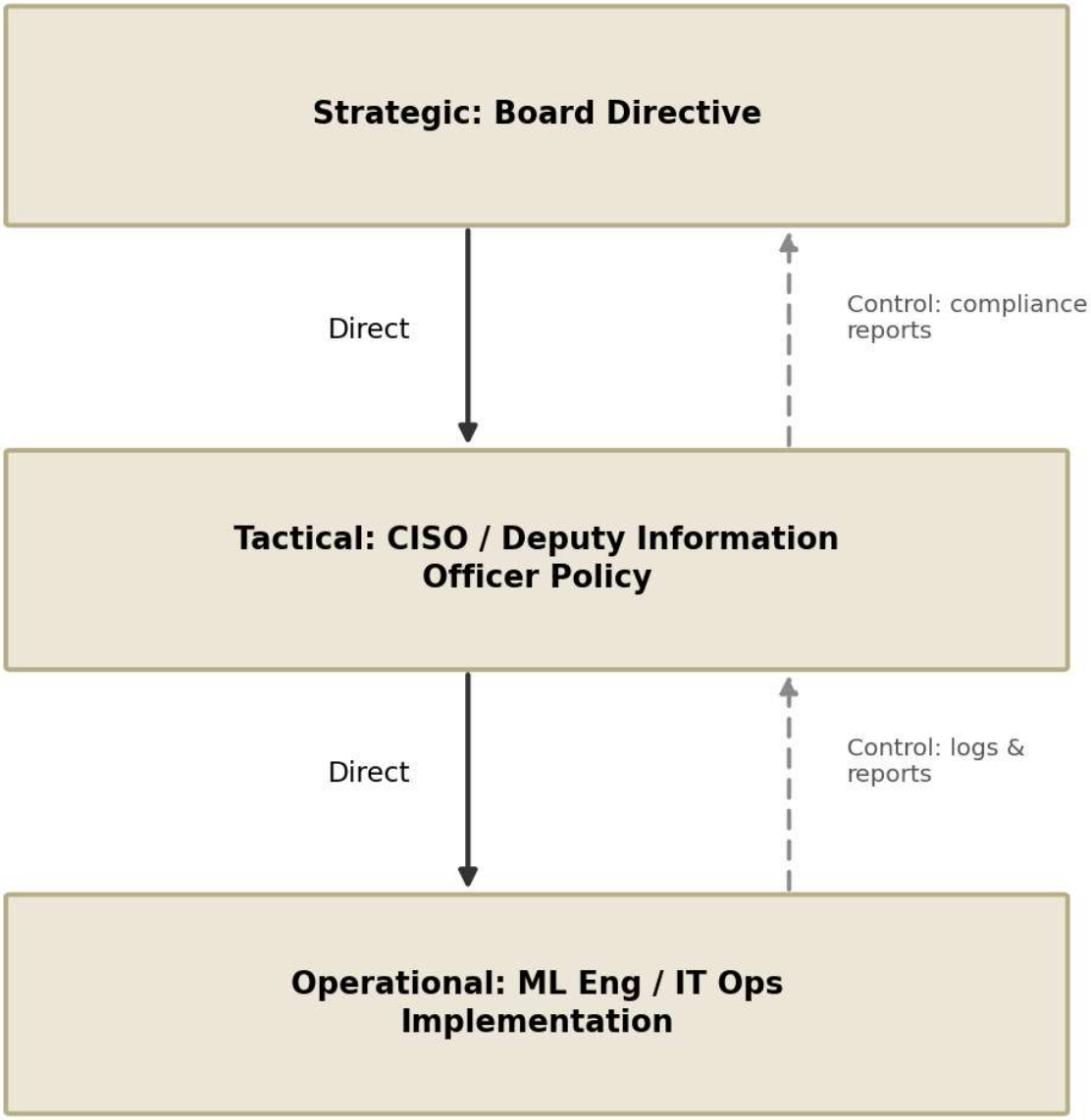


Figure 5: Cortexa AI InfoSec governance model - Direct and Control flows

ISG vs. ISM - why the full cycle matters: Information Security Management (ISM) alone - writing policies, keeping security technology running - never closes the loop back to the board. **Governance** requires the full Direct-Execute-Control cycle, starting and ending at the top. If Cortexa AI only manages (writes policies, deploys firewalls) without the Control leg reporting compliance back to the board, it has ISM, not ISG - and repeats the exact structural gap identified in Topic 1's Enron analysis.

Von Solms and Von Solms (2009) make the same point at book length: information security governance is the Board-level direction and control of information security, of which management of day-to-day security is only the operational part.

Implementation Roadmap for Cortexa AI

Building the governance structures described above is only useful if Cortexa AI can actually deliver them with the resources a ~350-person company has. A "big bang" rollout of every COBIT objective and ISO control at once would overwhelm a lean InfoSec function, so this framework is deployed over a 12-to-18-month, three-phase roadmap, prioritising the foundational Direct-Execute-Control elements first.

A common criticism of comprehensive frameworks such as COBIT 2019 is that they are resource-intensive and risk becoming a bureaucratic exercise that distracts from the actual business of delivering value. For a company of Cortexa AI's size, a "big bang" implementation would therefore be counterproductive. Guidance for mid-sized organisations stresses clear governance and defined responsibilities, with effort and budget allocated according to the organisation's risk level and maturity (IN Cyber News, 2025). The approach must be pragmatic, prioritising the foundational elements that deliver immediate risk reduction and create the conditions for later maturity. This framework therefore recommends the three-phase sequence shown in Figure 6 over a 12-to-18-month horizon.



Figure 6: Cortexa AI phased IT governance implementation roadmap (12-18 months)

Phase	Timeframe	Focus	Key milestones
Phase 1: Foundation	Months 1-3	Establishing the non-negotiable governance artefacts	Risk, Audit & Technology Committee formally adopts the framework; CEO signs the CISP (Topic 6); EDM01 activated; complete asset inventory completed
Phase 2: Operation and Control	Months 4-9	Operationalising the tactical layer	CISO stands up the risk register (APO12); Cloud & IT Operations Lead implements baseline controls (DSS05); first quarterly InfoSec KPI report delivered to the Committee, closing the Control leg of this Direct-Execute-Control loop
Phase 3: Assurance and Improvement	Months 10-18	Independent testing and continuous improvement	Internal Audit begins independent testing (MEA03, MEA04); first external assurance engagement on model-serving APIs; Balanced Scorecard fully embedded; ISO/IEC 27001 certification considered for client assurance

Phase 1: Foundation (Months 1-3). This phase is about establishing the non-negotiable governance artefacts. The Board, through its Risk, Audit & Technology Committee, formally adopts the IT governance framework. The first COBIT objective to be activated is EDM01 (Ensured governance framework setting and maintenance), which involves defining decision rights and accountability for AI and data as set out in the Topic 2 structure. Concurrently, the CEO, as Information Officer, signs the Corporate Information Security Policy (CISP) developed in Topic 6. This phase does not require a mature measurement capability; it requires clear, written directives from the top of the organisation. A critical early step is a complete asset inventory, as a governance framework cannot protect what it cannot identify.

Phase 2: Operation and Control (Months 4-9). With the foundation in place, the focus shifts to the tactical level. The CISO operationalises the risk register and the enterprise risk management processes (APO12). The Cloud & IT Operations Lead implements the baseline security controls (DSS05). The key milestone in this phase is the establishment of the MEA loop: the CISO produces the first quarterly Information Security KPI report for the Technology & Risk Steering Committee and the Board Committee, even if the initial metrics are sparse. This tests the Control function of the Direct-Execute-Control cycle and demonstrates that reporting lines are functional. A baseline capability rating for each priority COBIT objective should also be established using the COBIT 2019 capability levels, providing a starting point for measuring improvement.

Phase 3: Assurance and Improvement (Months 10-18). In this final phase, Internal Audit begins its independent testing of controls against the agreed objectives (MEA03, MEA04). The first external assurance engagement, covering the security of model-serving APIs, is commissioned. The Balanced Scorecard, which integrates security and compliance metrics alongside model performance and deployment velocity, is fully embedded. The organisation can now begin to consider formal certification against ISO/IEC 27001, a step that is increasingly required by finance and retail clients.

This phasing follows King IV's "apply and explain" logic (Topic 1): Cortexa AI first does the right things (Phase 1's directives and accountability), then does things right (Phase 2's operational discipline), before seeking independent assurance that the loop is actually closing (Phase 3).

Realising the Five ITG Objectives

The governance structure in Topic 2 is only an organogram until it is tied to a mechanism, an owner, and something the Board can check. The table below specifies how each of the five ITG objectives identified in Topic 2 is actually realised at Cortexa AI.

ITG objective	Cortexa AI mechanism	Accountable owner	Board indicator
Strategic Alignment	Annual I&T strategy workshop co-chaired by CEO and CTO; every AI roadmap item traceable to a business objective	CEO	Percentage of AI roadmap items traceable to a strategic objective
Value Delivery	Mandatory business case and post-implementation review for every production model	Head of ML Engineering	Realised vs projected client value per model

ITG objective	Cortexa AI mechanism	Accountable owner	Board indicator
Risk Management	CISO maintains a consolidated AI and information risk register; Committee reviews risks above the Board-approved appetite	CISO	Number of risks above appetite; age of the oldest open high risk
Resource Management	Quarterly review of cloud GPU expenditure, vendor contracts and skills capacity	CFO	Compute cost per production model; vacancy rate in critical security and ML roles
Performance Management	Balanced Scorecard integrating model performance, service level, security and compliance metrics	CISO	SLA attainment; trend in security KPIs (e.g. vulnerability closure time)

Critical Considerations for Implementation

Two further considerations are material to this roadmap's success. First, the CISO's position outside the technology delivery line (Topic 3) is vital for independence but requires active CEO backing to be effective in practice, particularly where security requirements slow a model's release; the Technology & Risk Steering Committee (Topic 2) is the forum where these tensions are resolved as policy, not personality. Second, the framework must stay resilient to change: Cortexa AI's risk profile today will not be its risk profile in 18 months, so the MEA domain and the Board's ongoing oversight role exist specifically to review and adapt the framework itself, not just to monitor a fixed set of controls.

King IV's "apply and explain" approach is instructive here: the Board should not merely assert that the framework exists but should be able to explain how it is producing the intended outcomes of effective control and legitimacy, and how it is being adapted as the organisation's risks evolve (IoDSA, 2016).

Justification of the Model's Design Choices

A governance model is only as credible as the reasons for its design. The table below records each major design decision, the alternative that was considered and rejected, and the theoretical or contextual justification for the choice.

Design choice	Alternative considered	Justification
Full Direct-Execute-Control cycle across three levels, starting and ending at the Board	A management-only model (policies and technology controls without a reporting loop)	Management alone is ISM, not ISG: without the Control leg the Board never learns whether its directives are honoured, which is the exact structural gap found at Enron (Topic 1; Von Solms and Von Solms, 2006)
CEO signs and owns the CISP; the CISO reports to the CEO with a dotted line to the Committee	CISO reporting to the CTO inside the technology line	Removes the conflict of interest between shipping models quickly and reporting their risk honestly; keeps unfavourable security information from being filtered before it reaches the Board (Topics 1 and 3)

Design choice	Alternative considered	Justification
Risk, Audit & Technology Committee plus an executive Technology & Risk Steering Committee chaired by the CEO	A separate board-level technology committee and a full-time security executive team	Proportionate to a company of about 350 people with scarce skills, while still ensuring that no single technology executive controls both delivery and risk reporting (Topic 2)
Phased 12-18 month roadmap that puts directives and accountability first	A "big bang" rollout of every COBIT objective and ISO control at once	Funding and skills are the binding constraints identified in the problem statement; foundations deliver immediate risk reduction and make later maturity possible
Measurable Compliance Clauses with different checking cycles (daily to six-monthly)	An annual audit report as the only compliance evidence	Course guidance is that annual or six-monthly audit reports are no longer sufficient; compliance evidence must be continuous and compilable into reports (Topic 7)

How the model answers the problem statement: the four challenges facing South African organisations map directly onto the design. *Inadequate funding* is met by phasing the roadmap and by using free or low-cost frameworks first (Topic 5). The *shortage of skilled professionals* is met by clear ownership, a lean CISO function and the option of managed security operations (Topic 3). *Outdated technology* is addressed by the baseline security controls in Phase 2 (DSS05), and *low awareness* by the SETA programme in Topic 9.

Topic 5: Best Practice Standards & Guidelines

ISMS (ISO 27000 definition): an Information Security Management System is the policies, procedures, guidelines and associated resources/activities an organisation manages to protect its information assets - established, monitored, maintained and improved through a cycle of identifying assets, assessing risk, selecting/implementing controls, and continual improvement (ISO, 2018a).

Frameworks vs. Standards (course distinction): a *framework* (COBIT, NIST CSF) is a flexible, adaptable methodology; a *standard* (ISO 27001) is mandatory criteria set by a recognised authority, generally certifiable.

	COBIT	ISO 27000 family
Focus	IT Governance (ITG)	InfoSec Governance (ISG)
Certification route?	No	Yes (via ISO 27001)
Official standard?	No	Yes
Detail	Less detailed	More detailed

ISO 27000 family, applied to Cortexa AI:

- **ISO 27000** - overview/vocabulary; defines ISMS requirements (ISO, 2018a).
- **ISO 27001** - the certifiable specification ("Requirements"); strict, all of Clauses 4-10 must be met to claim conformity (ISO, 2013). Cortexa AI could pursue this to reassure finance/retail clients.
- **ISO 27002** - a guideline/code-of-practice document (not mandatory) providing organisational, people, physical and technological controls (ISO, 2022) - the practical starting point for Cortexa AI's own InfoSec management effort.

NIST Cybersecurity Framework 2.0 (an alternative/complementary framework) (NIST, 2024): six functions - Govern, Identify, Protect, Detect, Respond, Recover - useful for Cortexa AI's technical/operational security controls around its ML pipeline.

Comparison of COBIT 2019, the ISO/IEC 27000 family and NIST CSF 2.0: the course compares COBIT with the ISO 27000 family on four criteria, shown in the first table above. Because the recommendation must also weigh NIST, the table below extends the comparison to all three options across the criteria that matter to Cortexa AI and sets out the strengths and weaknesses of each.

Criterion	COBIT 2019	ISO/IEC 27001 and 27002	NIST CSF 2.0
Issuing body and type	ISACA; a framework for the governance and management of enterprise IT	ISO/IEC; 27001 is a certifiable standard (ISMS requirements), 27002 is a code of practice (control guidance)	NIST; a voluntary framework
Primary focus	IT governance (ITG) and management	Information security governance and management (ISG)	Cybersecurity risk outcomes
Structure	40 governance and management objectives in five domains: EDM, APO, BAI, DSS, MEA	27001: Clauses 4-10 plus Annex A; 27002:2022: controls in four themes (organisational, people, physical, technological)	Six functions: Govern, Identify, Protect, Detect, Respond, Recover, with categories, Profiles and Tiers

Criterion	COBIT 2019	ISO/IEC 27001 and 27002	NIST CSF 2.0
Certification	No	Yes (via ISO/IEC 27001)	No
Level of detail	Less detailed on security	More detailed; prescriptive control catalogue	Outcome-based; less prescriptive
Cost and access	Core guidance published by ISACA; fuller material through ISACA resources	Standards must be purchased; certification adds audit cost	Free to download and use
Strengths	Separates governance (Board) from management; scalable to organisation size; gives Internal Audit a ready audit universe	Internationally recognised; certification gives independent client assurance; comprehensive controls; supports due diligence	Simple common language for engineers and executives; flexible; Govern function links security to enterprise risk
Weaknesses	Broad rather than security-specific; can become bureaucratic if over-implemented; no certification	All of Clauses 4-10 must be met to claim conformity, which is costly and slow for a new function	No certification or external assurance; limited governance structure detail; less control-level guidance

Evaluation against Cortexa AI's selection criteria: the options are scored below against the characteristics of Cortexa AI that drive the choice (Topic 3's dimension assessment and the problem statement).

Selection criterion	COBIT 2019	ISO/IEC 27001 / 27002	NIST CSF 2.0
Board-level accountability structure	Strong	Partial (leadership and policy clauses)	Partial (Govern function)
Independent assurance for finance and retail clients	None	Strong (27001 certificate)	None
Operational control detail for the ML pipeline	Partial	Strong	Partial (outcomes, mapped to other standards)
Affordability for a ~350-person company with a new InfoSec function	Moderate (can be tailored and phased)	Moderate if used as a guideline (27002); high if certified immediately (27001)	Strong (free and flexible)
AI-specific relevance	Partial	Partial (controls apply to ML systems but are not AI-specific)	Growing (AI-focused guidance in development) (NIST, 2025)

No single option scores strongly on every criterion, which is why the recommendation that follows combines them rather than choosing one: COBIT supplies Board accountability, ISO/IEC 27002 supplies control detail now and ISO/IEC 27001 supplies certifiable assurance later, and NIST CSF 2.0 gives engineering teams a practical checklist. The recommendation should be re-tested at the end of Phase 2 of the roadmap (Topic 4), when Cortexa AI will know its real capacity for certification.

Recommendation: per the course's own guidance, COBIT and ISO 27001/27002 are *complementary*, not competing. Cortexa AI should use **COBIT for its wider IT governance strategy** (Topic 2), while using **ISO 27002 to give operational content to its InfoSec sub-strategy** (Topics 6-8), with **ISO 27001 certification** as a longer-term goal for client assurance. NIST CSF's six functions are a useful practical checklist for the Protect/Detect/Respond controls implemented under that ISO 27002 sub-strategy.

Justifying the Framework Choices for Cortexa AI

The course asks that a framework not simply be named, but justified against the organisation it is applied to. Four characteristics of Cortexa AI drive the choices above.

Why COBIT 2019. Cortexa AI's primary IT governance risk is horizontal, not technical: the CTO who ships models fast and the CISO who must slow them down for security review report through different incentive structures (Topic 1's conflict-of-interest analysis). COBIT is justified here because it is the only one of the three frameworks that separates governance (EDM, owned by the Board) from management (APO, BAI, DSS, MEA, owned by executive and line management) as a first-class structural distinction (ISACA, 2018b) - exactly the separation Cortexa AI's organisational design in Topic 2 and Topic 3 depends on. It is also not a certifiable standard, so it imposes no audit cost on a company that cannot yet afford a certification programme, while still giving the Board a complete, globally recognised checklist against which to test governance maturity.

ISACA (2025) also publishes guidance on applying COBIT to the governance and management of AI systems, which supports using COBIT as Cortexa AI's Board-level structure for AI-specific risks such as model theft and data poisoning, rather than treating them as purely technical matters.

Why ISO/IEC 27002 (not 27001, yet). Cortexa AI's InfoSec function is new and under-resourced; full ISO 27001 compliance to the letter of every one of its Clause 4-10 requirements (ISO, 2013) would consume the entire team's capacity before a single control was improved. ISO 27002 is justified as the operational starting point instead because it is explicitly a code of practice, not a certifiable requirement (ISO, 2022): it gives Cortexa AI a comprehensive, internationally recognised control catalogue (the sub-policies in Topic 6-7 are drawn directly from it) without forcing an all-or-nothing certification audit the company is not ready for.

Why ISO/IEC 27001 as a longer-term goal, not a current one. Cortexa AI serves finance and retail clients who increasingly require formal security assurance from their vendors as a condition of contract; ISO 27001 certification is justified as the eventual target specifically because it is the only one of the three frameworks that produces an independently audited certificate a client's procurement team can verify (ISO, 2013), which COBIT and ISO 27002 cannot provide on their own. Pursuing it only once the ISO 27002 controls are operating avoids certifying a control environment that is not yet mature enough to pass audit.

Why NIST CSF 2.0 as a complementary check, not a replacement. COBIT and ISO 27002 are both control- and process-oriented; neither gives engineering teams a simple, function-based way to triage day-to-day security work. NIST CSF's six functions - Govern, Identify, Protect, Detect, Respond, Recover (NIST, 2024) - are justified as a practical overlay because they translate directly into the operational tasks the Cloud & IT Operations Lead and ML Engineering teams already perform (Topic 2's DSS and BAI domains), and because NIST has begun publishing AI-specific guidance extending the same functions to model and data risk (NIST, 2025), directly relevant to Cortexa AI's model-theft and data-poisoning exposure (Topic 8).

Why not rely on a single framework. Using COBIT alone would leave Cortexa AI with governance structure but no operational control detail; using ISO 27002 alone would leave operational controls with no board-level accountability structure; using NIST CSF alone would leave both governance and controls undefined at the policy level. The three frameworks are justified together, not individually, because each covers a gap the others leave open, and because King IV's own principle-based, rather than single-standard, approach to governance (Topic 1) supports combining complementary frameworks rather than mandating one.

Topic 6: Direct Part of the InfoSec Model - Board Structure & Policy Architecture

The course's "Direct Part" of the ISG model is built from the **Board Directive** down through the **Corporate Information Security Policy (CISP)**, forming Cortexa AI's Information Security Policy Architecture (ISPA) (Posthumus, Von Solms and King, 2010).

The policy architecture and its standards basis: ISO/IEC 27001 (Clause 5.2) requires top management to establish an information security policy appropriate to the organisation's purpose, and ISO/IEC 27002 (Control 5.1) requires a set of policies for information security to be defined, approved by management, published, communicated and reviewed at planned intervals (ISO, 2013; ISO, 2022). Cortexa AI meets both through a four-level hierarchy in which every document carries a measurable Compliance Clause (developed in Topic 7), so that the whole set forms a single, auditable ISPA (Nelson Mandela University, 2026d).

Level	Document	Purpose	Owner	Approver	Review
1. Direction	Board Directive	Records the Board's realisation of the importance of the company's AI and IT assets and its mandate to protect them	Board	Board	Annually, or on a material change in strategy
2. Policy	Corporate Information Security Policy (CISP)	High-level, technology-neutral policy that flows from the Directive and mandates everything below it	CISO	CEO signs; Committee approves	Annually
3. Sub-policies	Access Control; Data Protection and POPIA; Incident Response; Model and Training-Data Access; Third-Party AI Vendor; Malicious Software; Acceptable Use; Disaster Recovery; Remote Access	Define specific aspects of security in more detail	CISO (Data Protection: Deputy Information Officer)	CEO	At least annually
4. Procedures	e.g. Model/Data Access Procedure; Joiner-Mover-Leaver Procedure; Incident Reporting Procedure	Specify exactly how each sub-policy is implemented	Function heads (ML Engineering, Cloud & IT Operations, HR)	CISO	As required; at least annually

Cortexa AI Board Directive (example, following the course template):

> *"The Board of Cortexa AI accepts the importance of the company's AI models and IT infrastructure in furthering its strategic goals. The Board recognises the potential impact on the company, and consequences to clients, if this infrastructure or model IP is compromised. For this reason, the Board demands a proper environment to protect Cortexa AI's information assets, and fully supports an Information Security Governance environment for the company."*

The Directive meets both course requirements: it records the Board's realisation of the importance of Cortexa AI's models and infrastructure to its strategy, and it contains the Board's mandate to protect them. Its measurable Compliance Clause (detailed feedback to the Board on serious AI and model risks every three months) is set out in Topic 7.

Executive/board structure this implies: per course requirements, the CISP that flows from this Directive must (a) be signed by the CEO, (b) name a Policy Owner, and (c) name the responsibilities of other roles. Cortexa AI therefore structures oversight as:

- **CEO** signs and owns the CISP (not the CTO - avoiding the conflict-of-interest identified in Topic 1, where the person accountable for shipping AI fast should not also control the person saying "not secure enough to ship").
- **CISO** is named in the CISP as responsible for day-to-day InfoSec governance, reporting to the CEO.
- **Board** receives compliance reporting per the Directive's Compliance Clause (Topic 7).

Executive and Board Oversight Structure

A board meets infrequently and cannot supervise a technical function directly, so the Direct part needs a defined structure that carries Board direction down to management and carries assurance back up. Figures 2 and 4 show where each body sits; the table below sets out what each body decides (Direct), what it receives (Control) and how often.

Recent research on board-level governance and risk oversight for Artificial Intelligence systems reinforces the case for giving AI risk explicit Board-level ownership instead of leaving it inside the technology function (Kumar and Jaya, 2026); the structure below is how Cortexa AI does this.

Body or role	Direct: what it decides	Control: what it receives	Cadence
Board of Directors	Issues the Board Directive; approves the risk appetite and, through its Committee, the CISP; accountable for governing technology and information (King IV Principles 11 and 12)	Quarterly report from the Committee; independent assurance on ISG	At least quarterly
Risk, Audit & Technology Committee (Board sub-committee)	Approves the CISP and material policy changes; sets and reviews risk appetite (EDM03); challenges management on AI and information risk	Quarterly KPI and risk-profile report from the CISO (direct access); Internal Audit findings; major incident reports	Quarterly, plus ad hoc for major incidents
Chief Executive Officer (Information Officer)	Signs and owns the CISP; allocates resources; accountable for POPIA compliance; chairs the Technology & Risk Steering Committee	Consolidated reports from the Steering Committee and the CISO	Monthly
Technology & Risk Steering Committee (chair: CEO; CTO, CISO, CFO, Head of Data & ML, Deputy Information Officer)	Translates Board direction into the I&T plan; prioritises investment; resolves security versus delivery trade-offs as policy rather than personality	Performance and risk reports from the management domains (APO, BAI, DSS, MEA)	Monthly

Body or role	Direct: what it decides	Control: what it receives	Cadence
Chief Information Security Officer (Policy Owner)	Owns the CISP and security strategy; sets security requirements for every team; owns the risk register	Aggregated operational data: logs, vulnerability status, incident and compliance reports	Monthly to the CEO; quarterly to the Committee
Deputy Information Officer (Head of Legal & Compliance)	Runs the POPIA compliance programme; manages engagement with the Information Regulator	Breach, notification and data-subject request logs	Quarterly, and as incidents occur
Internal Audit	Plans independent assurance over the ISPA and its Compliance Clauses	Evidence from compliance reporting at every level	Annual plan; reports to the Committee quarterly

Strategic alignment: the structure aligns with the governance goals of the framework in four ways. It places ultimate accountability where King IV places it, with the governing body (Principles 11 and 12; IoDSA, 2016). It reproduces COBIT's separation of governance (EDM, owned by the Board and Committee) from management (APO, BAI, DSS and MEA) (ISACA, 2018b) and ISO/IEC 38500's Evaluate-Direct-Monitor cycle (ISO/IEC, 2015). It gives each of the six ISG principles a named owner (Topic 3). And it closes the Direct-Execute-Control loop by making every Direct decision above produce a Control report below, so that Cortexa AI has governance rather than merely management (Topic 4).

Design justification: the CEO, not the CTO, signs and owns the CISP and the CISO has a dotted-line right of access to the Committee because the executive accountable for shipping AI quickly should not also control the voice that says a model is not yet secure enough to ship (Topic 1). A separate board-level technology committee would be disproportionate for a company of about 350 people, so the Committee combines risk, audit and technology oversight and the executive Steering Committee carries the detailed work (Topic 2).

The Corporate Information Security Policy (CISP)

The CISP is the foundational document of the information security governance framework and the formal expression of the Board's directive on protecting the organisation's electronic assets. The CISO is the Policy Owner and is responsible for its maintenance. The CEO, as Information Officer, signs the policy, thereby accepting executive accountability for its implementation, and the Board approves it through the Risk, Audit & Technology Committee.

The CISP is concise, written in plain language and accessible to every employee. Its purpose is to state the organisation's commitment to information security, define its scope, articulate the core principles that guide all security activity and assign high-level responsibilities. The core principles of the CISP for Cortexa AI are:

This follows guidance for mid-sized organisations that every actor must know exactly the scope of their own responsibilities and that the policy must be reviewed regularly, because threats, attack methods and tools change quickly (IN Cyber News, 2025).

- **Confidentiality:** information is accessible only to those with a legitimate need-to-know.

- **Integrity:** information and systems are accurate, complete and protected from unauthorised modification.
- **Availability:** information and systems are accessible to authorised users when required.
- **Compliance:** all processing of personal information is conducted in accordance with POPIA and other applicable law.
- **Accountability:** every employee, contractor and vendor is accountable for adhering to this policy and the sub-policies it authorises.

The high-level statements in the CISP, each of which carries its own Compliance Clause in Topic 7, cover: the information security organisational structure and roles; classification and handling of information; logical access to systems, data and models; personnel security from screening to exit; third-party and supplier access; incident management and notification; business continuity and disaster recovery; and compliance with law, including POPIA and the Cybercrimes Act. (Republic of South Africa, 2021)

CISP requirements (course checklist) applied to Cortexa AI: must indicate Board/executive support; signed by the CEO; 4-5 pages, non-technical, high-level; technology-neutral (must not name specific tools so it doesn't need rewriting each time infrastructure changes); must name the Policy Owner (CISO) and other roles' responsibilities; must state its Scope (all Cortexa AI staff and contractors); must reference disciplinary action for non-conformance; must be distributed widely and covered in awareness training (Topic 9); must carry a Compliance Clause (Topic 7).

Sub-Policy Detail: Access Control, Data Protection and Incident Response

Three sub-policies carry the greatest weight given Cortexa AI's risk profile (Topic 8: R4 unauthorised access to client PII, R6 insider exfiltration of model weights and R7 regulatory non-compliance with POPIA), so they are written out here with the purpose, scope, control areas and ownership that the course's ISPA template requires. Two further sample policies are drafted and peer-reviewed in Topic 7.

Access Control Policy

Access control is the most fundamental technical control for protecting the confidentiality and integrity of Cortexa AI's assets. The Access Control Policy operationalises the Board's risk appetite for R4 (unauthorised access to client PII) and R6 (insider exfiltration) in the Topic 8 risk register.

Purpose: to ensure access to Cortexa AI's systems, data and models is granted on business need and least privilege, and reviewed, monitored and revoked in a timely manner.

Scope: all employees, contractors, vendors and partners who access Cortexa AI's systems, including cloud infrastructure, model repositories and client data.

Control area	Key practice
Role-Based Access Control (RBAC)	Access rights assigned by job function via a formal user access matrix; granted only after management approval and completion of security awareness training

Control area	Key practice
Multi-Factor Authentication (MFA)	Mandatory for all users without exception, for remote access, privileged access, and access to Confidential or Restricted data
Access review and revocation	Reviewed quarterly by the asset owner; accounts disabled immediately on termination; access rights updated within 24 hours of a role change
Privileged access management	Administrative privileges granted sparingly, for specific tasks only; privileged sessions logged and monitored
Audit and monitoring	All access to Restricted data and all administrative actions logged; SOC monitors for anomalous access patterns

Owner: CISO. Approver: CEO.

Data Protection and POPIA Compliance Policy

This policy addresses the legal and ethical obligations of Cortexa AI as a responsible party under the Protection of Personal Information Act (POPIA) and provides the framework for treating client data with the integrity needed to maintain trust and competitive advantage. It operationalises the controls for R4 (PII exposure) and R7 (regulatory non-compliance).

Purpose: to ensure that all personal information processed by Cortexa AI is handled lawfully, with appropriate technical and organisational measures to protect its confidentiality and integrity, and in compliance with POPIA and the company's ethical commitments.

Scope: all personal information processed by Cortexa AI, whether relating to clients, employees or other data subjects, across every stage of the data lifecycle: collection, storage, use, sharing and deletion.

Control area	Key practice
Lawful processing and consent	Personal information is processed only with a lawful basis, such as the consent of the data subject or the necessity to perform a contract; the purpose of processing is stated clearly at the point of collection
Data classification and handling	All data is classified using the four-tier scheme (Public, Internal, Confidential, Restricted); client personal information is Restricted and subject to the strictest access controls
Information Officer duties	The CEO, as Information Officer, is accountable for POPIA compliance; the Head of Legal & Compliance acts as Deputy Information Officer and manages the compliance programme
Breach notification (POPIA s22)	On reasonable grounds to believe that personal information has been accessed or acquired by an unauthorised person, the Information Officer notifies the Information Regulator and the affected data subjects as soon as reasonably practicable, following the documented procedure
Data subject rights	Procedures allow data subjects to exercise their rights under POPIA, including access, correction and objection to processing
Data retention and deletion	Personal information is retained only as long as necessary to fulfil the purpose for which it was collected; secure deletion procedures apply when the retention period expires

Owner: Head of Legal & Compliance (Deputy Information Officer), on behalf of the CEO (Information Officer). Approver: CEO.

Incident Response Policy

Purpose: to define the structure, roles and processes for detecting, responding to and recovering from information security incidents, including suspected data breaches.

A mature incident response capability is the operational embodiment of the Control function in the Direct-Execute-Control cycle. This policy ensures that when a security incident occurs the organisation responds in a coordinated, timely and transparent manner, minimising impact and fulfilling its legal and contractual obligations.

Scope: all employees, contractors and third parties who become aware of a potential security incident affecting Cortexa AI's systems or data.

Control area	Key practice
IRP stages	Identification, Containment, Eradication, Recovery, Post-Incident Review
Incident reporting	All suspected or actual incidents reported immediately to the Security Operations function via a dedicated email address and escalation hotline
Roles and responsibilities	CISO is Incident Response Manager; Cloud & IT Operations Lead handles technical containment and recovery; Head of Legal & Compliance assesses legal and regulatory notification obligations
Communication and escalation	An escalation matrix defines thresholds and contacts for informing the CEO, the Board Committee, clients and the Information Regulator; all external communication is approved by the CEO and Legal
Evidence preservation	Forensic evidence (logs, memory captures, system images) preserved in a manner that maintains its integrity for potential legal or disciplinary proceedings
Testing and drills	IRP tested annually through a tabletop exercise; post-incident reviews are mandatory and feed back into the plan

Owner: CISO. Approver: CEO.

Policy Review and Maintenance

All information security policies at Cortexa AI, including those above, are reviewed at least annually by the CISO and the IT Management Team. The review considers changes in the risk landscape, new regulatory requirements, the findings of audits and incident investigations, and the evolving business strategy. Material changes are approved by the CEO and reported to the Board Committee. This keeps the policy framework a living system of control rather than a static document.

Topic 7: Control Part of the InfoSec Model - Operational Policies & Compliance

Sub-policies (course-defined set) adapted for Cortexa AI, each sitting beneath the CISP (Topic 6), consistent with ISO 27001 Clause 5.2 and ISO 27002 Control 5.1 on establishing and maintaining security policies (ISO, 2022):

1. **Malicious Software Control Policy** - anti-malware on all endpoints and build pipelines.
2. **Acceptable Internet/Email Usage Policy** - no client data or credentials pasted into external tools (feeds Topic 9's awareness campaign).
3. **Logical Access Control Policy** - named, individual credentials for all access to production models and training datasets; no shared service accounts. Written out in full in Topic 6.
4. **Disaster Recovery (Backup) Policy** - model weights and training data backed up and recoverable.
5. **Remote Access Control Policy** - secure VPN/MFA for engineers accessing production systems remotely.
6. **Third-Party Access Control Policy** - governs cloud GPU providers, data-labelling contractors, and any foundation-model API vendors: security questionnaire before onboarding, no client data used to train a vendor's own models, time-boxed and quarterly-reviewed access.

Each sub-policy is supported by **Procedures** specifying implementation (course example: an Internet Usage Procedure requiring line-manager approval for new connectivity requests - Cortexa AI's equivalent: a Model/Data Access Procedure requiring CISO sign-off before any model-weight export).

Compliance Clauses (Control Part, course template): every ISPA document needs a measurable Compliance Clause, since "a policy that cannot be measured has no value." Examples adapted for Cortexa AI:

Document / Statement	Compliance Clause
Board Directive	Detailed feedback on serious AI/model risks reported to the Board every 3 months
CISP - organisational structure	Effectiveness of the InfoSec structure evaluated every 6 months, results in higher-level reporting
CISP - logical access (Statement 6.6 equivalent)	Daily report of unauthorised access attempts to models/training data; discrepancies escalated
CISP - business continuity	Model-serving and data-pipeline continuity tested every 6 months, results reported to Executive Management
Access Control Policy	Access rights reviewed quarterly by the asset owner; a report of reviewed, changed and revoked accounts goes to the CISO and is summarised for the Committee
Incident Response Policy	IRP tested annually by tabletop exercise; every incident followed by a post-incident review reported to Executive Management
Data Protection and POPIA Policy	Notification log reviewed monthly; every notifiable compromise reported to the Information Regulator and affected data subjects as soon as reasonably practicable, with the decision and date recorded
Model & Training-Data Access Policy	Report of de-identification approvals and model-weight exports produced for each release; any export without CISO sign-off escalated as an incident

Document / Statement	Compliance Clause
Third-Party AI Vendor Policy	Vendor access and security questionnaires reviewed quarterly; every emergency revocation reported to the CISO within one working day

Different clauses run on different cycles (daily vs. six-monthly) - the course stresses there's no one-size-fits-all cycle, only that every clause must produce a report that can actually be compiled.

Compliance Management: From Periodic Audit to Continuous Measurement

ISO/IEC 27002 (Control 5.36) requires compliance with the organisation's information security policies, rules and standards to be reviewed regularly (ISO, 2022). The traditional approach relies on an ICT audit section that periodically performs an audit and produces a report. Such reports remain important because they highlight problems in the protection of ICT assets, but the course is clear that an audit report once every year, or even once every six months, is no longer acceptable: compliance enforcement must be far more immediate and dynamic (Nelson Mandela University, 2026d).

Cortexa AI therefore keeps Internal Audit as the independent third line (COBIT MEA03 and MEA04) but complements it with Compliance Clauses that generate evidence continuously. Operational data, such as firewall and model-access logs, database records and the model registry, is aggregated into compliance reports at the operational level; the CISO and Executive Management consolidate these into the quarterly report to the Committee, which is the Control leg of the Direct-Execute-Control cycle (Topic 4). Where a clause cannot be reported on, the statement behind it is rewritten, because a policy that cannot be measured has no value.

Sample Policies Drafted for Peer Review

The course requires each team to draft two sample policies and to peer-review another group's policy for gaps. The two policies below target the AI-specific risks that matter most to Cortexa AI (R1 data poisoning, R2 model theft, R6 insider exfiltration and R9 third-party vendor breach in Topic 8). They are shown in their final form, after the review feedback that follows was incorporated.

Policy 1: Model & Training-Data Access Policy

Purpose: to ensure that model weights, source code and training datasets are accessible only to authorised, named individuals with a documented business need, and that client personal information is de-identified before it is used for training. Scope: all employees, contractors and vendors with access to model repositories, training datasets or the model registry.

Control area	Key practice
Need-to-know access	Access to model weights, source code and training datasets is granted per project on a documented business need; the data owner (Head of Data & ML) approves each request
Named credentials	Every access uses an individual named credential; shared accounts and shared service credentials are prohibited; each service account has a named owner and is rotated on a fixed schedule

Control area	Key practice
De-identification before training	Client personal information must be anonymised or pseudonymised before it enters a training dataset; the CISO (or a delegate) approves the de-identification check and records the approval in the model registry; a dataset that fails the check is quarantined and cannot be used until it is reprocessed and re-approved
Model export and release	Export of model weights outside approved environments requires CISO sign-off under the Model/Data Access Procedure; production deployment requires ML Engineering Lead sign-off through the model registry
Logging and review	All access to training data and model artefacts is logged; access rights are reviewed quarterly by the data owner; anomalies are reported to Security Operations

Owner: CISO. Approver: CEO.

Policy 2: Third-Party AI Vendor Policy

Purpose: to ensure that cloud GPU providers, data-labelling contractors and foundation-model API vendors meet Cortexa AI's security and data protection requirements throughout the relationship, from onboarding to exit.

Scope: every third party that hosts, processes, labels or has access to Cortexa AI data, client data or models.

Control area	Key practice
Onboarding due diligence	A completed security questionnaire and CISO review are required before any access is granted; vendors that process personal information sign a written operator agreement consistent with POPIA
Contractual terms	No client data may be used to train a vendor's own models; confidentiality, breach-notification and audit-right clauses are mandatory and reviewed by Legal & Compliance
Access control	Vendor access is time-boxed, limited to the minimum data needed and reviewed quarterly by the CISO
Emergency revocation	Access is revoked immediately, outside the quarterly cycle, on a vendor security incident, suspected compromise or contract termination; the CISO may order revocation without prior notice
Incident notification	Vendors must notify Cortexa AI promptly of any compromise affecting its data, so that the POPIA section 22 notification process can start without delay
Monitoring and offboarding	Vendor activity is logged; on exit, credentials are revoked and data is returned or securely deleted, with written confirmation

Owner: CISO. Approver: CEO.

Peer-review feedback:

On the Model & Training-Data Access Policy: Clear on who needs access and why, and the requirement for named credentials over shared accounts is a strong, specific control. Could be tightened further: the policy states data must be "anonymised or pseudonymised" but doesn't say who verifies this before training begins, or what happens if a dataset fails that check. Recommend adding a named approver for that step so the control is actually enforceable, not just aspirational.

On the Third-Party AI Vendor Policy: Good coverage of onboarding (security questionnaire) and contractual terms (no training on client data). The gap is offboarding: the policy says access is "time-boxed and quarterly-reviewed" but doesn't specify what triggers immediate revocation (e.g. a vendor security incident, contract termination). Recommend adding a clause for emergency revocation outside the normal quarterly cycle.

Response/incorporation: Both gaps were addressed in the final policy wording above by naming the CISO as the approver for data de-identification checks (Policy 1) and adding time-boxed access controls that can be revoked ahead of the quarterly cycle if needed (Policy 2).

Topic 8: IT Risk Management - Assessment & Mitigation

Risk terminology (course): a risk = an asset + a threat + a vulnerability (ISO, 2018a). Risk size = impact (if the threat materialises) × probability/frequency (that the threat exploits the vulnerability). Controls reduce either the impact or the probability, or both.

This risk terminology follows ISO 31000, the generic guideline for establishing, implementing and reviewing a risk management process (ISO, 2018b); Cortexa AI's risk register should be reviewed against it even though the worked examples below are illustrative rather than based on live incident data.

Risk management process (ISO/IEC 27005:2022): Cortexa AI applies the cyclical process in ISO/IEC 27005:2022: context establishment, risk assessment (identification, analysis and evaluation), risk treatment, and ongoing communication, monitoring and review (ISO/IEC, 2022). This process is the operational engine of the risk-governance mandate in King IV Principle 11 and the mechanism through which the Board's risk appetite, set under COBIT's EDM03 (Ensured risk optimisation), is translated into management action under APO12 (Managed risk) (ISACA, 2018b).

Context establishment: the risk context is defined by Cortexa AI's position as a South African mid-sized AI company serving finance and retail clients. It includes the POPIA obligations that apply to client personal information in training data, contractual service levels, the intellectual-property value of proprietary models and the commercial need to deploy models quickly. The Board-approved risk appetite must balance the pursuit of commercial opportunity against the duty to protect the company's assets and its clients' data.

Risk identification: risks are identified through several channels: the asset inventory (the electronic-asset table in Topic 2), scenario-analysis workshops with technical teams, review of security alerts and incident logs, and consultation with Legal & Compliance on regulatory developments. For an AI company the taxonomy must extend beyond traditional CIA concerns to AI-specific risks such as model drift, data poisoning, adversarial examples and algorithmic bias; NIST's AI-focused cybersecurity guidance offers a complementary structure for organising them (NIST, 2025).

The NIST AI Risk Management Framework and the draft Cyber AI Profile offer a complementary structure for organising these considerations, focusing on securing AI systems, using AI for defence and defending against AI-enabled attacks (NIST, 2025).

Risk analysis approach: Cortexa AI used a **combined formal-informal approach** - informal (top-down: "we're worried client credit-scoring data could leak" → analysed into asset = training data, threat = theft) for board-level concerns, and formal (bottom-up: asset = model weights, threat = exfiltration via API → risk deduced) for engineering-level analysis.

Each risk is analysed on impact (the consequence for confidentiality, integrity, availability, compliance and reputation) and likelihood, producing a risk level (Critical, High, Medium or Low) that is compared against the Board's risk appetite. Risks above the appetite are deemed unacceptable and require treatment. The analysis is conducted by the CISO with input from the relevant asset owners.

Quantitative evaluation (Annual Loss Expectancy) - worked example: if Cortexa AI's proprietary fraud-detection model (asset) is exfiltrated via an unsecured API (threat), and the impact of one theft is estimated at R500,000 (client contract loss + reputational damage), with a probability of 0.3 incidents/year based on current API monitoring gaps, the **Annual Loss Expectancy = R500,000 × 0.3 = R150,000/year**.

Qualitative evaluation (Likert 1-5): impact is scored from 1 (insignificant) to 5 (disastrous) and probability from 1 (hardly ever) to 5 (very often). The risk score is impact multiplied by probability and is banded as Low (1-4), Medium (5-9), High (10-19) or Critical (20-25). The twelve risks below combine the eight principal asset-based risks of the AI pipeline (R1 to R8) with four operational and human-factor risks (R9 to R12).

Table 8.1: Quantitative (Likert) scoring of Cortexa AI's information security risks

Risk	Impact (1-5)	Probability (1-5)	Risk Score	Mitigation
R1 Training-data poisoning	4 (Major)	3 (Regularly)	12 (High)	Data validation pipeline; source vetting; anomaly detection pre-training
R2 Model theft via API	5 (Disastrous)	3 (Regularly)	15 (High)	Rate-limiting, API monitoring, model watermarking, access logging (Topic 7)
R3 Model drift	3 (Significant)	4 (Often)	12 (High)	Continuous performance monitoring; drift alerts; retraining procedure
R4 Unauthorised access to client PII	5 (Disastrous)	3 (Regularly)	15 (High)	Role-based access with least privilege; mandatory MFA; PII classified Restricted (Topic 6)
R5 Cloud provider outage	3 (Significant)	3 (Regularly)	9 (Medium)	Multi-zone deployment; tested disaster recovery for model weights; contractual SLAs
R6 Insider exfiltration of model weights	5 (Disastrous)	2 (Seldom)	10 (High)	Endpoint and cloud-storage DLP; confidentiality clauses; access revocation at exit
R7 Regulatory non-compliance with POPIA	3 (Significant)	3 (Regularly)	9 (Medium)	Deputy Information Officer; documented s22 procedure; regular compliance reviews (Topic 6)
R8 Adversarial attack on model API	3 (Significant)	2 (Seldom)	6 (Medium)	Input validation; adversarial training; API gateway controls
R9 Third-party vendor data breach	4 (Major)	2 (Seldom)	8 (Medium)	Vendor security questionnaire, contractual clauses, quarterly access review (Topic 7)
R10 Algorithmic bias / discriminatory outcomes	3 (Significant)	3 (Regularly)	9 (Medium)	Bias testing pre-release, model documentation (Topic 5, NIST CSF)
R11 Shadow ML models deployed without review	4 (Major)	4 (Often)	16 (High)	Mandatory model registry; ML Eng Lead sign-off before production deployment
R12 Staff pasting client data into public AI tools	3 (Significant)	4 (Often)	12 (High)	Awareness campaign (Topic 9); Acceptable Usage Policy (Topic 7)

Risk treatment plan: following ISO/IEC 27005, each risk is treated by modification (applying controls), retention (accepting the residual risk), avoidance (ceasing the activity) or sharing (transferring through insurance or

contracts) (ISO/IEC, 2022). The plan below records the strategy, the controls, the accountable owner and the target residual level once the controls are operating.

Table 8.2: Risk treatment plan and target residual risk

Risk	Treatment strategy	Controls and actions	Owner	Target residual risk
R1 Data poisoning	Modify	Dataset versioning and hash verification; strict write-access controls on labelled datasets; anomaly detection on data ingestion	Head of Data & ML	Medium
R2 Model theft	Modify / Share	Rate-limiting and anomaly detection on API calls; adversarial-robustness techniques; cyber-insurance to cover IP loss	CISO / CTO	Medium
R3 Model drift	Modify	Continuous model performance monitoring; automated alerts when drift exceeds defined thresholds; retraining procedures	Head of ML Engineering	Medium
R4 Unauthorised access to client PII	Modify	Role-based access control with least privilege; mandatory MFA for all data access; data classification marking PII as Restricted	CISO	Medium
R5 Cloud provider outage	Modify / Share	Multi-zone cloud deployment; tested disaster recovery for model weights; contractual SLAs with the cloud provider	Cloud & IT Operations Lead	Low
R6 Insider exfiltration of model weights	Modify	Endpoint data loss prevention; DLP on cloud storage; contractual confidentiality and access revocation at exit	CISO / Chief People Officer	Medium
R7 POPIA non-compliance	Modify	Deputy Information Officer appointed; documented POPIA s22 notification procedure; regular compliance reviews by Legal	Head of Legal & Compliance	Low
R8 Adversarial attack on model API	Modify	Input validation and sanitisation; adversarial training during model development; API gateways with signature verification	Head of ML Engineering	Low
R9 Third-party vendor breach	Modify / Share	Security questionnaire; contractual clauses (no training on client data, breach notification); quarterly access review; emergency revocation	CISO	Low
R10 Algorithmic bias	Modify	Bias testing before release; model documentation; periodic fairness review	Head of Data & ML	Low
R11 Shadow ML models	Modify	Mandatory model registry; ML Engineering Lead sign-off before production deployment; periodic discovery scans	Head of ML Engineering	Low
R12 Client data in public AI tools	Modify	Awareness campaign (Topic 9); Acceptable Usage Policy; approved internal AI tools as the easy alternative; DLP on browser uploads	CISO with HR	Medium

Risk register and treatment plan (Board view). Table 8.3 presents the register in the form the Risk, Audit & Technology Committee reviews: each risk is scored, its treatment strategy specified (modification, retention, avoidance or sharing; ISO/IEC, 2022) and an accountable owner named.

Table 8.3: Cortexa AI information security risk register and treatment plan

Risk ID	Risk Description	Asset at Risk	Impact	Likelihood	Risk Level	Treatment Strategy	Controls / Actions	Owner
R1	**Data poisoning:** Deliberate corruption of training data pipelines leads to biased or inaccurate model predictions.	Training-data pipelines	Critical	Medium	High	Modify	Implement dataset versioning and hash verification; enforce strict write-access controls on labelled datasets; anomaly detection on data ingestion.	Head of Data & ML
R2	**Model extraction/theft:** Adversaries reverse-engineer proprietary models through the prediction API, eroding competitive advantage.	Proprietary model weights	Critical	Medium	High	Modify / Share	Rate-limiting and anomaly detection on API calls; use of adversarial robustness techniques; cyber-insurance to cover IP loss.	CISO / CTO
R3	**Model drift:** Production models degrade in accuracy due to changes in the underlying data distribution, leading to poor client outcomes and SLA breaches.	Model-serving APIs	High	High	High	Modify	Implement continuous model performance monitoring; automated alerts when drift exceeds defined thresholds; retraining procedures.	Head of ML Engineering
R4	**Unauthorised access to client PII:** An external breach or insider misuse exposes personal information in training data, triggering POPIA liability and client loss.	Client training data	Critical	Medium	High	Modify	Role-based access control with least privilege; mandatory MFA for all data access; data classification marking PII as Restricted.	CISO
R5	**Cloud provider outage:** Failure of the cloud GPU infrastructure leads to an inability to serve model predictions, breaching client SLAs.	Model-serving infrastructure	High	Medium	Medium	Modify / Share	Multi-zone cloud deployment; tested disaster recovery for model weights; contractual SLAs with cloud provider.	Cloud & IT Ops Lead
R6	**Insider exfiltration of model weights:** A malicious or negligent employee copies proprietary model artefacts to an external location.	Model source code and weights	Critical	Low	High	Modify	Endpoint data loss prevention; DLP on cloud storage; contractual confidentiality and access revocation at exit.	CISO / CPO
R7	**Regulatory non-compliance with POPIA:** Failure to comply with Information Officer duties or breach notification obligations leads to enforcement action and fines.	All personal information	High	Medium	Medium	Modify	Appointment of Deputy Information Officers; documented POPIA s22 notification procedure; regular compliance reviews by Legal.	Head of Legal & Compliance

Risk ID	Risk Description	Asset at Risk	Impact	Likelihood	Risk Level	Treatment Strategy	Controls / Actions	Owner
R8	**Adversarial attack on model API:** Maliciously crafted inputs cause the model to produce incorrect or harmful outputs.	Model-serving APIs	High	Low	Medium	Modify	Input validation and sanitisation; adversarial training during model development; API gateways with signature verification.	Head of ML Engineering
R9	**Third-party vendor breach:** A cloud, data-labelling or API vendor holding Cortexa AI or client data is breached, exposing client information.	Client data held by vendors	Critical	Low	Medium	Modify / Share	Security questionnaire before onboarding; contractual clauses (no training on client data, breach notification); quarterly access review; emergency revocation.	CISO
R10	**Algorithmic bias:** Models produce systematically unfair or discriminatory outcomes for clients or their customers.	Model outputs and decisions	High	Medium	Medium	Modify	Bias testing before release; model documentation; periodic fairness review.	Head of Data & ML
R11	**Shadow ML models:** Models are deployed to production without security, risk or ethics review.	Production environment	Critical	High	High	Modify	Mandatory model registry; ML Engineering Lead sign-off before production deployment; periodic discovery scans.	Head of ML Engineering
R12	**Client data in public AI tools:** Staff paste client data into public AI tools, which is then retained or exposed outside Cortexa AI.	Client data (Confidential)	High	High	High	Modify	Awareness campaign (Topic 9); Acceptable Usage Policy (Topic 7); approved internal AI tools; DLP on browser uploads.	CISO with HR

Key: for Board reporting, the numeric scores in Table 8.1 are expressed qualitatively. Impact 4-5 (Major, Disastrous) is shown as Critical and impact 3 (Significant) as High; probability 2 (Seldom) is Low, 3 (Regularly) is Medium and 4 (Often) is High. The resulting risk level is the banded score in Table 8.1. R1 to R8 are the principal asset-based risks and R9 to R12 are operational and human-factor risks.

Mapping AI threats to ISO/IEC 27001 Annex A controls. Advisera (2024) links AI-specific threats such as data poisoning, model extraction, model inversion, biased information and adversarial attacks to Annex A controls of the 2022 revision of ISO/IEC 27001. Table 8.4 shows how the main controls relate to Cortexa AI's register; the pairing of risks to controls is our own judgement, adapted from that source.

Table 8.4: Indicative mapping of register risks to ISO/IEC 27001:2022 Annex A controls (adapted from Advisera, 2024)

Annex A control	What it addresses	Related risks
A.5.9 Inventory of information and other associated assets	Knowing which models, datasets and pipelines exist and who owns them	R1, R2, R11
A.5.12 Classification of information	Marking training data and client PII as Restricted or Confidential	R4, R12
A.5.15 Access control	Only authorised people can change ML systems, data and model weights	R1, R2, R4, R6

Annex A control	What it addresses	Related risks
A.5.19 Information security in supplier relationships	Externally supplied AI and cloud services meet Cortexa AI's security requirements	R5, R9
A.5.31 Legal, statutory, regulatory and contractual requirements	POPIA and client contract obligations	R4, R7
A.8.25 Secure development life cycle	Validation, adversarial testing and review before release	R1, R3, R8, R10, R11

Risk heat map: the principal asset-based risks (R1 to R8) are plotted below by qualitative impact and likelihood. For Board reporting, impact of Major or Disastrous (4-5) is expressed as Critical and Significant (3) as High; likelihood of Seldom (2) is Low, Regularly (3) is Medium and Often (4) is High. R9 to R12 are scored in the table above.

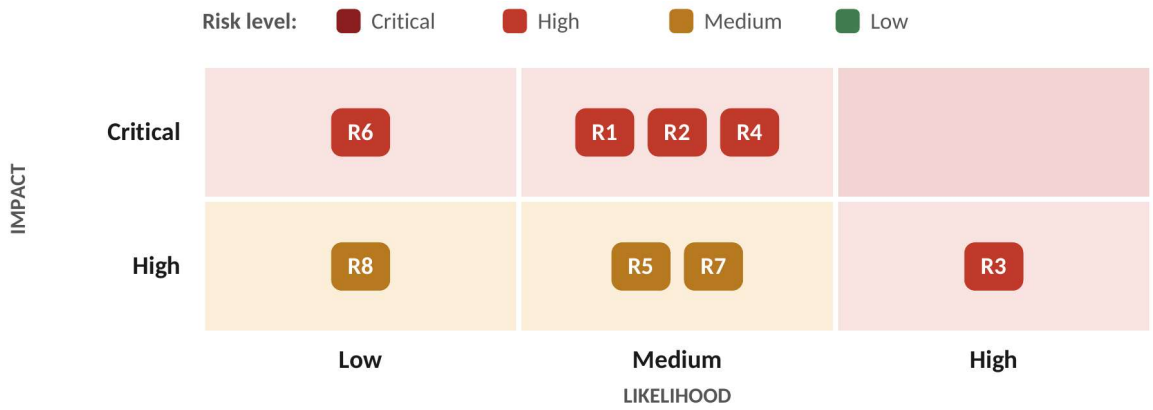


Figure 7: Cortexa AI risk heat map - risks R1 to R8 plotted by impact and likelihood

Risk treatment: controls must reduce risk to an acceptable level while balancing legal/regulatory constraints (POPIA), organisational objectives, operational constraints, and the cost of the control against the harm it prevents (ISO/IEC, 2022) - e.g. the model-theft risk (score 15) justifies real investment (watermarking, monitoring) given its Annual Loss Expectancy above, while lower-scored risks are addressed on the standard review cycle. Residual risk (what remains after treatment) is reported up through the Control leg of the Direct-Execute-Control cycle (Topic 4).

Risk evaluation and residual risk: once the controls in the treatment plan are implemented, residual risk is re-evaluated, with the objective of bringing every risk within the Board-approved appetite. R1 (data poisoning) reduces from High to Medium with dataset versioning and hash verification, and R3 (model drift) reduces from High to Medium with continuous monitoring and automated retraining triggers. The residual risk for R6 (insider exfiltration) may remain at Medium, but the combination of technical controls and contractual obligations brings it within an acceptable tolerance.

Residual risk method. Residual risk is the score after the controls in Table 8.2 are operating. Each risk is re-scored with the same 1-5 scales, and the controls are credited with lowering either the probability or the impact. The scores below are Cortexa AI's target values, to be confirmed by the Risk, Audit & Technology Committee once evidence of control operation exists. We propose a Board-approved appetite that tolerates Low and Medium

residual risk (score 9 or below), with a named owner and quarterly review for every Medium risk, while any High or Critical residual risk is escalated to the Board and cannot be accepted by management alone.

Table 8.5: Inherent and target residual risk for R1 to R12

Risk	Inherent score	Residual impact	Residual probability	Residual score	Why it reduces
R1 Data poisoning	12 (High)	4	2	8 (Medium)	Dataset versioning, hash verification and write-access controls lower the probability.
R2 Model theft	15 (High)	4	2	8 (Medium)	Rate-limiting and anomaly detection lower the probability; watermarking and cyber-insurance lower the impact.
R3 Model drift	12 (High)	3	2	6 (Medium)	Continuous monitoring and automated retraining triggers catch drift early.
R4 Unauthorised access to client PII	15 (High)	4	2	8 (Medium)	Least-privilege RBAC and MFA lower the probability; classification and minimisation limit the impact.
R5 Cloud provider outage	9 (Medium)	3	1	3 (Low)	Multi-zone deployment and tested recovery make a prolonged outage very unlikely.
R6 Insider exfiltration	10 (High)	4	2	8 (Medium)	DLP and revocation at exit lower the probability; watermarking supports legal recourse. Remains Medium.
R7 POPIA non-compliance	9 (Medium)	3	1	3 (Low)	Deputy Information Officer and a documented s22 procedure.
R8 Adversarial attack on API	6 (Medium)	3	1	3 (Low)	Input validation, adversarial training and gateway controls.
R9 Third-party vendor breach	8 (Medium)	3	1	3 (Low)	Due diligence, contractual clauses and emergency revocation.
R10 Algorithmic bias	9 (Medium)	2	2	4 (Low)	Pre-release bias testing and periodic fairness review.
R11 Shadow ML models	16 (High)	4	1	4 (Low)	Model registry and sign-off make unreviewed deployment very unlikely.
R12 Client data in public AI tools	12 (High)	3	3	9 (Medium)	Behaviour change is gradual; DLP and approved tools help. Stays Medium until Topic 9 metrics improve.

Figure 8 plots all twelve risks before and after treatment. Seven risks are High before treatment (R1, R2, R3, R4, R6, R11 and R12); after treatment none is. Six end at Medium (R1, R2, R3, R4, R6 and R12, with scores of 6 to 9) and six at Low (R5, R7, R8, R9, R10 and R11), so no residual risk sits above the Board's appetite. The six Medium risks are the focus of the quarterly review.



Figure 8: Cortexa AI risk heat map - inherent and target residual risk for R1 to R12 (impact x probability)

The Risk, Audit & Technology Committee reviews the register quarterly. The key metrics reported to the Board, as defined in the Topic 4 implementation plan, are the number of risks above appetite and the age of the oldest open high risk. The Board's role is not to manage these risks but to provide oversight, to ensure that the risk appetite is still appropriate to the organisation's strategy and to seek assurance that the treatment plans are effective.

Critical observations: the assessment reveals a concentration of high-risk exposure in the data and model integrity domain (R1, R2, R3 and R6). This is characteristic of AI companies, where the core value proposition depends on the trustworthiness and exclusivity of intangible assets. Traditional IT risk frameworks, focused on infrastructure security, are not adequate for these risks, so the governance response must integrate model risk management into the enterprise risk framework, with the Board providing oversight of AI risk as it would of any other material business risk.

The assessment also underscores the interconnected nature of the controls. The effectiveness of the R1 (data poisoning) controls depends on the access controls for R4 (unauthorised access) and on configuration management of the data pipelines. This interdependency reinforces the lesson from the Enron case (Topic 1): a failure in one part of the governance system can cascade through the whole, so the Direct-Execute-Control loop must be monitored holistically rather than as a set of isolated controls.

Topic 9: InfoSec Education, Training & Awareness (SETA)

Why SETA matters (course): 68% of all cyberattacks involve the human element (Verizon, 2024) - people, not technology, are the primary attack vector. ISO 27002 Control 6.3 (ISO, 2022) requires an awareness, education and training programme aligned to policy, delivered periodically, with understanding assessed afterward.

This 68% figure excludes malicious privilege misuse and focuses on errors and social engineering, both of which are directly addressable through awareness and training (Verizon, 2024).

Awareness, training and education: the course draws a clear distinction between the three, and the programme is pitched at the correct level of detail for each audience, because SETA programmes fail when they include too much technical detail (Nelson Mandela University, 2026e). Employees must be taught how to follow the prescribed procedures (training) and why they must follow them (education).

Level	Question it answers	Audience at Cortexa AI	Example at Cortexa AI
Awareness	What is the threat, and what is my role in stopping it?	All employees and contractors	Posters, the monthly CISO near-miss email, the Information Security Day
Training	How do I do my job securely?	Role-specific groups: ML engineers, data labellers, cloud operations, HR, client-facing staff	Hands-on sessions on the model registry, the Model/Data Access Procedure and approved AI tools
Education	Why does it work this way, and how do I design and manage security?	Security team, CISO, Head of Data & ML, Internal Audit	Formal courses in information security management and AI system security

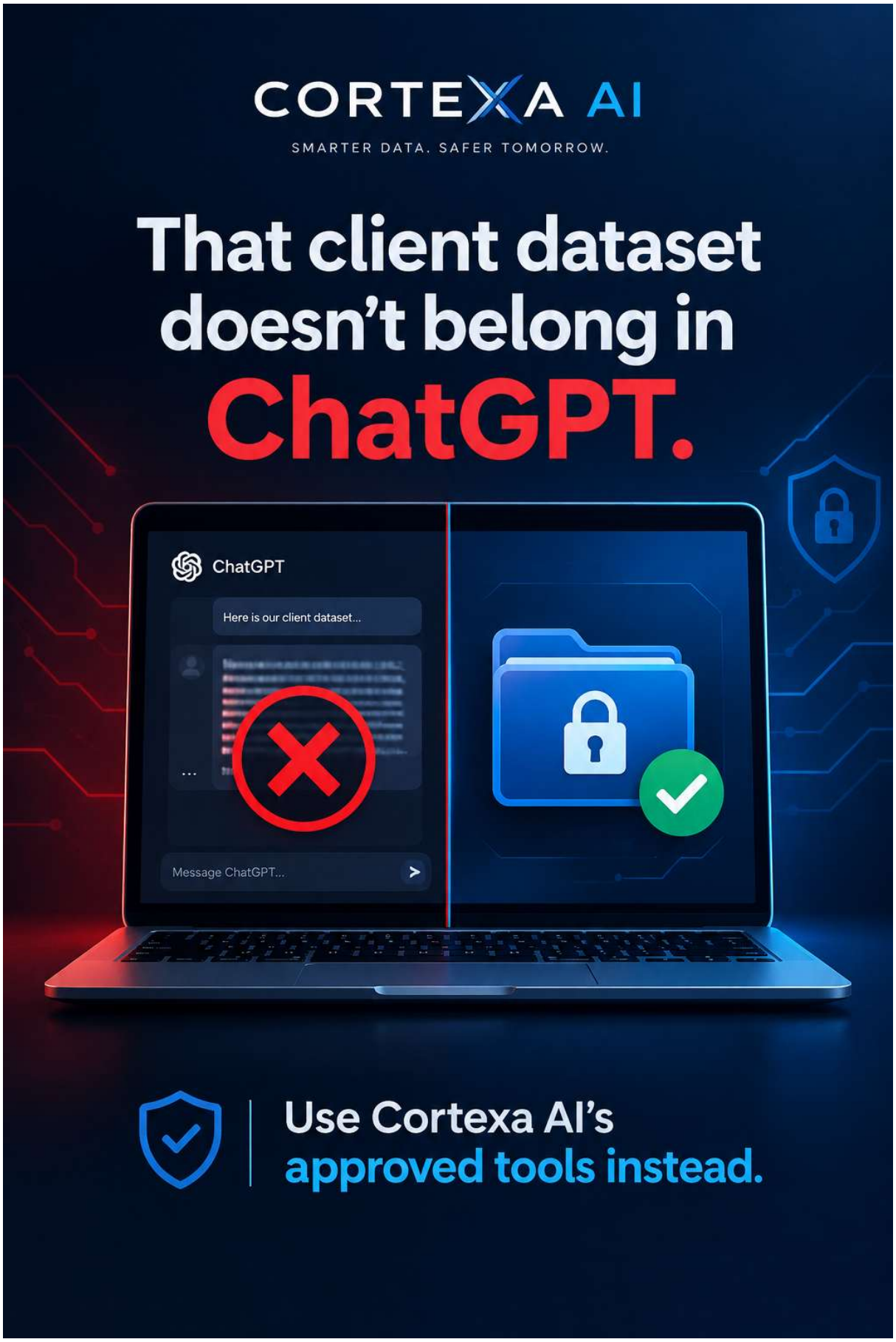
Campaign - "Think Before You Prompt" (targets Cortexa AI's highest-frequency human-error risk from Topic 8: staff pasting client data into public AI tools):

- Training sessions: why information is a critical asset; the CISP and sub-policies (Topic 6-7); each employee's role/responsibility; consequences of non-compliance.
- Posters/regular communication: "That client dataset doesn't belong in ChatGPT", "Your API key is a master key", monthly CISO email with one real (anonymised) near-miss.
- InfoSec knowledgebase + Information Security Day: onboarding materials, incident-reporting contacts, and an annual high-visibility awareness day.

- Poster 1: "Your API key is a master key" - a single key opening doors to Client Data, Model Weights, and Production Systems, with the caption "Treat it like one. Never share it, never paste it in code you commit."



- **Poster 2:** "That client dataset doesn't belong in ChatGPT" - a split-screen laptop showing a blocked ChatGPT paste on one side and a secure, approved-tool folder on the other, captioned "Use Cortexa AI's approved tools instead."



Grounded in the Conscious Competence Learning Model (the course's behaviour-change framework): Cortexa AI's programme is designed to move staff through all four stages, not just deliver information once:

1. **Unconscious Incompetent** - most new hires don't realise pasting data into an external AI tool is a risk; the campaign's job is first to make them aware they're doing something wrong.
2. **Conscious Incompetent** - once aware, they're trained on the correct procedure (the Acceptable Usage Policy, Topic 7).
3. **Conscious Competent** - they follow the policy but still have to think about it.
4. **Unconscious Competent** - through repetition (regular reminders, not one-off training), secure behaviour becomes automatic.

Avoiding known SETA failure modes (course-specific pitfalls to design around, per Winkler, 2022, ch. 2): the campaign avoids **checkbox mentality** (an annual tick-box session isn't enough - use ongoing monthly touchpoints); avoids the **information-action fallacy** (telling people the "why" doesn't guarantee behaviour change - pair awareness with an enforced Acceptable Usage Policy, Topic 7); and collects **Day-0 metrics** (baseline rate of policy violations) before rollout so the programme's actual impact can be measured, not assumed.

Three further pitfalls identified in the course are also designed around: *overestimating the role of awareness* (awareness is paired with technical controls such as data loss prevention and an approved-tool alternative, so the environment reduces the opportunities for user-initiated loss); *unaddressed mental models* (the belief that "it won't happen to me" is countered with anonymised near-miss stories from Cortexa AI itself); and *inappropriate expectations* (the programme promises risk reduction, not elimination) (Winkler, 2022).

Campaign Materials and Delivery Plan

Sample awareness email (monthly CISO near-miss message):

> *Subject: Near miss of the month - a client dataset almost went into a public chatbot*
>
> *Hi team, last month an engineer pasted a sample of client credit-scoring data into a public AI tool to fix a formatting error. Our monitoring caught it within minutes and no data left our control, but only just. This is anonymised and nobody is in trouble: the real lesson is that it could happen to any of us on a busy day.*
>
> *Why it matters: client data is protected by POPIA, and one paste can become a reportable breach and cost us the trust of the clients who pay our salaries. What to do: use Cortexa AI's approved tools; never paste client data, API keys or model code into an external tool; if you are unsure, ask the security team before you paste. If you do make a mistake, report it straight away on the incident address - reporting quickly is always the right call.*
>
> *It takes two minutes: complete the "Think Before You Prompt" micro-lesson on the InfoSec knowledgebase. Thank you for keeping our clients' data safe. - Chief Information Security Officer*

Mock presentation: ten-minute all-hands session delivered by the CISO with a Head of Data & ML co-presenter:

Segment	Time	Content
Hook	1 min	A masked screenshot of client data about to be pasted into a public chatbot; ask the room what could go wrong
Why it matters	2 min	68% of attacks involve the human element (Verizon, 2024); the cost of one POPIA breach; the Enron lesson that structures do not help if people do not act
The rule in plain words	2 min	The Acceptable Usage Policy and CISP in three sentences: what is allowed, what is not, and what happens on non-compliance
The right way	2 min	Live demonstration of the approved internal tool and secure dataset folder, showing that the secure route is also the easy route
Reporting	1 min	How to report a mistake or near miss: dedicated email address and escalation hotline, no blame for fast reporting
Commitment and quiz	1 min	Three-question pulse quiz and a one-line pledge from each team lead
Questions	1 min	Open questions; unanswered items go onto the InfoSec knowledgebase

Delivery timeline and measurement: Day-0 metrics are collected before launch so that the programme's real effect can be shown rather than assumed. The campaign launches in month 1 with the training sessions and posters, continues with a monthly CISO email and a quarterly micro-quiz, and peaks annually with the Information Security Day. The targets below are proposals to be calibrated once the baseline is known.

Metric	Day-0 baseline	Proposed target	Source
DLP-blocked or reported attempts to paste client data into public AI tools	Measured before launch	Fewer repeat events per 100 staff each quarter	DLP and proxy logs
Time from incident to report by staff	Measured from recent incidents	Reduced year on year	Incident log
Pulse-quiz score on the Acceptable Usage Policy	Pre-campaign quiz	Improving score at each quarterly quiz	Learning platform
Training completion and attendance	Zero at launch	All staff within the first quarter; all new hires at onboarding	HR training records

Conclusion

The governance failures examined through King IV and the Direct-Execute-Control cycle (Topic 1) - no board-level directive, no independent assurance, no control loop back to the top - have direct analogues in how a mid-sized AI company like Cortexa AI can fail today, just with model weights and training data in place of off-balance-sheet entities. This framework closes those gaps end to end: an ITG structure mapped to COBIT's five objectives (Topic 2) with named, principle-based ownership and a full responsibility matrix (Topic 3); a complete Direct-Execute-Control governance model, with a phased roadmap and justified design choices, not just management (Topic 4); a justified COBIT, ISO and NIST standards approach (Topic 5); a Board Directive, executive oversight structure, CISP and the Access Control, Data Protection and Incident Response policies naming real accountability (Topic 6); operational sub-policies, two peer-reviewed sample policies and measurable compliance clauses (Topic 7); a quantified, prioritised risk register with treatment plan and residual risk (Topic 8); and a SETA programme built on the Conscious Competence model rather than a checkbox exercise (Topic 9).

Taken together, these give Cortexa AI's leadership what Enron's board never had: visibility into the risk they are actually carrying, and a structure that makes someone accountable for acting on it.

Reflection: Building this framework made clear that governance failure is rarely a single bad decision; it is a structural gap in the Direct-Execute-Control loop that goes unnoticed until something breaks. The hardest part was not designing individual controls (policies, risk scores) but making sure they connected to each other and back up to the board, since a policy or risk register that stops at the operational level is management, not governance. If this project were repeated, more time would be spent earlier on mapping how each topic's output feeds the next one, rather than treating each week as a standalone deliverable. A stronger peer-review process (with real, not simulated, external feedback) would also have caught gaps in the operational policies sooner.

References

Advisera (2024) *ISO 27001 and artificial intelligence - Which controls should be used to manage threats?* Available at: https://advisera.com/articles/how-to-handle-artificial-intelligence-threats-using-iso-27001/ (Accessed: 3 October 2026).

Healy, P.M. and Palepu, K.G. (2003) 'The fall of Enron', Journal of Economic Perspectives, 17(2), pp. 3-26. Available at: https://doi.org/10.1257/089533003765888403 (Accessed: 4 October 2026).

IN Cyber News (2025) *SMEs and Mid-Sized Companies: How to Structure a Cybersecurity Policy*. Available at: https://incyber.org/en/article/smes-and-mid-sized-companies-how-to-structure-a-cybersecurity-policy/ (Accessed: 3 October 2026).

Information Regulator (South Africa) (n.d.) POPIA guidance: Information Officers. Pretoria: Information Regulator. Available at: https://inforegulator.org.za/popia/ (Accessed: 23 September 2026).

Institute of Directors in Southern Africa (IoDSA) (2016) *King IV Report on Corporate Governance for South Africa*. Johannesburg: IoDSA. Available at: https://cdn.ymaws.com/www.iodsa.co.za/resource/collection/684B68A7-B768-465C-8214-E3A007F15A5A/IoDSA_King_IV_Report_-WebVersion.pdf (Accessed: 23 September 2026).

International Organization for Standardization and International Electrotechnical Commission (ISO/IEC) (2015) ISO/IEC 38500:2015 - Information technology - Governance of IT for the organization. Geneva: ISO. Available at: https://www.iso.org/standard/62816.html (Accessed: 4 October 2026).

International Organization for Standardization and International Electrotechnical Commission (ISO/IEC) (2022) ISO/IEC 27005:2022 - Information security, cybersecurity and privacy protection - Guidance on managing information security risks. Geneva: ISO.

International Organization for Standardization (ISO) (2013) *ISO/IEC 27001:2022 - Information technology - Security techniques - Information security management systems - Requirements*. Geneva: ISO. Available at: https://www.iso.org/standard/54534.html (Accessed: 23 September 2026).

International Organization for Standardization (ISO) (2018a) *ISO/IEC 27000:2018 - Information technology - Security techniques - Information security management systems - Overview and vocabulary*. Geneva: ISO. Available at: https://webstore.iec.ch/en/publication/62675 (Accessed: 23 September 2026).

International Organization for Standardization (ISO) (2018b) *ISO 31000:2018 - Risk management - Guidelines*. Geneva: ISO. Available at: https://www.iso.org/standard/65694.html (Accessed: 23 September 2026).

International Organization for Standardization (ISO) (2022) *ISO/IEC 27002:2022 - Information security, cybersecurity and privacy protection - Information security controls*. Geneva: ISO. Available at: https://www.iso.org/standard/75652.html (Accessed: 23 September 2026).

ISACA (2018a) *COBIT 2019 Framework: Governance and Management Objectives*. Schaumburg, IL: ISACA.

ISACA (2018b) *COBIT 2019 Framework: Introduction and Methodology*. Schaumburg, IL: ISACA. Available at: https://www.isaca.org/resources/cobit (Accessed: 23 September 2026).

ISACA (2025) *Leveraging COBIT for Effective AI System Governance and Management*. White Paper. Schaumburg, IL: ISACA.

IT Governance Institute (ITGI) (2006) Information Security Governance: Guidance for Boards of Directors and Executive Management. 2nd edn. Rolling Meadows, IL: ITGI.

Kumar, K. and Jaya, J. (2026) 'Board-level governance and risk oversight framework for Artificial Intelligence systems'. Published online 23 March 2026. Taylor & Francis. Available at: https://www.tandfonline.com/doi/full/10.1080/07366981.2026.2645658 (Accessed: 3 October 2026).

Lexology (2021) South Africa: Cybercrimes Act - summary of offences. Available at: https://www.lexology.com/library/detail.aspx?g=d1d7d561-0687-416c-b3a3-fb2f0bfe16cc (Accessed: 23 September 2026).

National Institute of Standards and Technology (NIST) (2024) *The NIST Cybersecurity Framework (CSF) 2.0*. Gaithersburg, MD: NIST. Available at: https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20 (Accessed: 23 September 2026).

National Institute of Standards and Technology (NIST) (2025) *Draft NIST Guidelines Rethink Cybersecurity for the AI Era*. Available at: https://www.nist.gov/news-events/news/2025/12/draft-nist-guidelines-rethink-cybersecurity-ai-era (Accessed: 3 October 2026).

Nelson Mandela University (2026a) ISC402 Information Security, Topic 1: Introduction to Corporate Governance [Lecture slides]. Gqeberha: School of Information Technology. Unpublished course material.

Nelson Mandela University (2026b) ISC402 Information Security, Topic 2: Information Technology Governance [Lecture slides]. Gqeberha: School of Information Technology. Unpublished course material.

Nelson Mandela University (2026c) ISC402 Information Security, Topic 3: InfoSec and InfoSec Governance [Lecture slides]. Gqeberha: School of Information Technology. Unpublished course material.

Nelson Mandela University (2026d) ISC402 Information Security, Topics 7 and 8: Direct and Control Parts of the ISG Model [Lecture slides]. Gqeberha: School of Information Technology. Unpublished course material.

Nelson Mandela University (2026e) ISC402 Information Security, Topic 9: InfoSec Education, Training and Awareness (SETA) [Lecture slides]. Gqeberha: School of Information Technology. Unpublished course material.

Organisation for Economic Co-operation and Development (OECD) (2023) G20/OECD Principles of Corporate Governance 2023. Paris: OECD Publishing. Available at: https://doi.org/10.1787/ed750b30-en.

Posthumus, S., Von Solms, R. and King, M. (2010) 'The board and IT governance: The what, who and how', *South African Journal of Business Management*, 41(3), pp. 23-32. Available at: https://www.econstor.eu/bitstream/10419/218442/1/sajbm-v41i3-0522.pdf (Accessed: 23 September 2026).

Republic of South Africa (2013) Protection of Personal Information Act 4 of 2013. Pretoria: Government Printer. Available at: https://inforegulator.org.za/popia/.

Republic of South Africa (2021) Cybercrimes Act 19 of 2020. Government Gazette No. 44651, 1 June 2021. Pretoria: Government Printer. Available at: https://lawlibrary.org.za/akn/za/act/2020/19 (Accessed: 9 October 2026).

United States Senate Permanent Subcommittee on Investigations (US Senate PSI) (2002) The Role of the Board of Directors in Enron's Collapse. Senate Print 107-70. Washington, DC: US Government Printing Office. Available at: https://www.govinfo.gov/content/pkg/CPRT-107SPRT80393/html/CPRT-107SPRT80393.htm (Accessed: 4 October 2026).

Verizon (2024) *2024 Data Breach Investigations Report*. New York: Verizon. Available at: https://www.verizon.com/business/resources/reports/2024-dbir-executive-summary.pdf (Accessed: 23 September 2026).

Von Solms, B. (2001) 'Information security - a multidimensional discipline', Computers & Security, 20(6), pp. 504-508.

Von Solms, R. and Von Solms, S.H. (2006) 'Information Security Governance: A model based on the direct-control cycle', Computers & Security, 25(6), pp. 408-412.

Von Solms, S.H. and Von Solms, R. (2009) Information Security Governance. New York: Springer.

Weston, D. (2024) 'Helping our customers through the CrowdStrike outage', Official Microsoft Blog, 20 July. Available at: https://blogs.microsoft.com/blog/2024/07/20/helping-our-customers-through-the-crowdstrike-outage/.

Winkler, I. (2022) *Security Awareness For Dummies*. Hoboken, NJ: John Wiley & Sons.